

文件編號：ICST-C-005

103年資安服務暨專案管理辦公室

安全軟體設計參考指引

(V1.0)

執行單位：財團法人資訊工業策進會

中華民國103年10月

報告摘要

報告名稱	安全軟體設計參考指引
資訊等級	☐機密　☐密　☐內部使用　☒普通
相關撰稿人	張元傑、蔡宗霖、蔡思玟、陳佳伶、楊惟傑
閱讀對象	☒一般主管　☒資安人員　☒資訊人員　☐一般使用者

內容摘要：

一、目的

本指引透過探討安全軟體設計方法論，包含如微軟 SDL, NIST SP 800-64, OWASP SAMM 等，歸納各方法論共通之重點，彙整出安全軟體設計重要流程步驟，協助相關人員於軟體設計時，因應軟體風險管理議題，進行資產識別、風險評鑑、風險分析與風險處理過程，作為後續開發階段遵循與驗證之依據。

本指引輔以 Web 開發與行動威脅分析兩案例分析，提供單位於軟體專案開發中藉由需求階段與設計階段之安全需求發展、安全風險識別及控制措施套用，以作為後續安全功能驗證基礎，期能落實安全軟體生命週期之實踐，從設計先期(Security design in)即著手整體資訊系統之安全性，強化政府整體安全軟體發展能量。

二、適用對象

本參考指引適用於軟體發展領域之所有對象，包含一般主管、資安人員及資訊人員，並針對不同對象建議說明其使用效益。

- 一般主管，例如資訊部門主管或軟體專案管理者，為確保軟體開發專案或組織使用之現有系統的安全性，於自行開發系統時可使用本指引來計畫安全設計活動與人力分配規劃之參考，或於委外開發之軟體專案或系統時用

於擬訂需求書或合約時參考使用。

- 軟體架構與設計者，如系統架構師與軟體設計師，參考這份指引介紹之方法論找出系統潛藏的資安弱點與可能面臨的安全威脅，進而設計相關防護措施以強化系統設計階段時之軟體安全特性。
- 軟體開發者，透過本指引之介紹理解安全軟體設計之原理與其重要性，於實做時理解安全設計之精神，進而達到軟體安全品質之提高與安全開發意識之提昇的目的。

三、章節架構

第 1 章說明本指引之目的、適用對象及章節架構介紹。

第 2 章說明介紹各種安全軟體設計標準與方法論，如 MS-SDL、OWASP Software Assurance Maturity Model (SAMM)與 NIST SP800-64，作為本指引參考文獻。

第 3 章就安全軟體設計階段中，各階段進行的實務活動進行說明，「安全設計原則」，說明應該進行系統設計時，應該參考使用的設計原則。「執行攻擊面分析」，說明進行攻擊面的定義、識別與對應方式，包含如何進行攻擊面的衡量與評估，並進行管理等。「執行風險分析」說明軟體設計過程中，如何透過使用威脅建模(Threat Modeling)與架構風險分析(Architecture Risk Analysis)，進行系統架構與威脅的分析，並介紹通用性的安全設計原則與控制措施，提供軟體安全風險分析與控制。「安全設計審查」說明在進行一連安全軟體設計的實務活動之後，應確保安全設計符合需求階段提出的相關安全需求及安全設計，能滿足軟體安全的基準線。

第 4 章案例分析以常見之 Web 應用程式，及行動裝置應用程式設計為例。示範如何使用 MS Threat Modeling 工具進行威脅分析，並選擇接受該威脅或套用控制措施，再經套用 DREAD 評鑑標準對威脅進行評分與計算權重，產出開發過程中對於風險威脅之分析與處理措施表，確保系統資安風險經

此風險處理流程後，將資安風險緩解至組織可接受之層級，而過程中所產生之控制處理措施將回饋至系統需求文件中，作為後續功能驗收與確認之來源依據。

第 5 章「結論」，總結各章節內容。

第 6 章「參考文獻」，詳列本指引參考的文件資料。

關鍵詞	安全軟體設計、安全軟體生命週期

目　次

1. 前言 1
1.1. 目的 1
1.2. 適用對象 1
1.3. 章節架構 2
2. 安全軟體設計標準與方法論 3
2.1. 微軟「安全發展生命週期」SDL 與安全設計 3
2.2. NIST SP 800-64 與安全設計 7
2.3. Software Assurance Maturity Model (SAMM) 12
2.4. 軟體安全設計與風險管理 19
3. 安全軟體設計階段實務活動 23
3.1. 安全設計原則 23
3.2. 安全設計模式 28
3.3. 執行攻擊面(Attack Surface)分析 36
3.4. 執行風險分析 39
3.5. 控制措施 74
3.6. 安全設計審查(Secure Design Review) 76
4. 案例分析 82
4.1. 案例一 Web 應用程式 82
4.2. 案例二 Mobile Threat Analysis 107
5. 結論 113
6. 參考文獻 114

圖 目 次

圖 1　微軟 SDL 4
圖 2　系統發展生命週期示意圖 8
圖 3　SAMM 架構圖 12
圖 4　SP800-30 風險分析流程圖 21
圖 5　單一存取模式範例-網路商店系統 29
圖 6　檢查點模式範例-網路商店系統 31
圖 7　角色模式範例-網路商店系統 32
圖 8　角色模式範例-網路商店系統 34
圖 9　安全存取層架構圖 36
圖 10　風險分析流程 40
圖 11　威脅建模流程 41
圖 12　MS-Style Threat Modeling 流程圖 43
圖 13　Example of DFD 45
圖 14　STRIDE 範例圖 49
圖 15　攻擊樹狀圖範例 55
圖 16　威脅建模安裝畫面 58
圖 17　建立資料流圖形 59
圖 18　STRIDE 分析介面 60
圖 19　排除風險選項 60
圖 20　排除特定風險選項 61
圖 21　建立環境剖繪 62
圖 22　產生威脅建模報告 63
圖 23　架構風險分析示意圖 64
圖 24　架構風險分析子流程 66

圖 25　信任建模步驟 1 68
圖 26　信任建模步驟 2 69
圖 27　信任建模步驟 3 70
圖 28　軟體架構 73
圖 29　安全設計審查流程 77
圖 30　網頁部落格資料流程圖 84
圖 31　網頁部落格分析模型列表 85
圖 32　網頁部落格刪除文章竄改分析 86
圖 33　行動裝置應用程式 Attack Tree 109
圖 34　行動裝置應用程式 Attack Tree Mitigation 111

表 目 次

表 1　擴大 vs 減少受攻擊面 5
表 2　威脅評鑑等級表 14
表 3　安全需求等級表 15
表 4　安全架構等級表 16
表 5　設計檢視等級表 18
表 6　參與人員 39
表 7　資料流組成元素 44
表 8　STRIDE 47
表 9　資料流元素對應的威脅類型 48
表 10　DREAD 評鑑標準 50
表 11　DREAD 風險值計算標準 50
表 12　風險計算範例 51
表 13　因應對策範例 51
表 14　風險分析範例系統角色表 52
表 15　系統物件列表 53
表 16　Subject-Object Matrix 範例 53
表 17　Subject-Object Matrix 反轉範例 54
表 18　威脅建模工具支援環境 57
表 19　控制措施 73
表 20　安全要求與控制措施範例 76
表 21　軟體安全特點不安全設計範例 79
表 22　網頁部落格功能列表 82
表 23　網頁部落格威脅與控制措施對應表 86
表 24　網頁部落格風險接受表 88

表 25　網頁部落格資料流 TID 分析表 89
表 26　網頁部落格資料儲存庫 TRID 分析表 91
表 27　網頁部落格外部實體 SR 分析表 92
表 28　網頁部落格程序 STRIDE 分析表 93
表 29　網頁部落格威脅對應評分表 94
表 30　網頁部落格安全功能表 99
表 31　網頁部落格安全需求追溯矩陣範例 102
表 32　OWASP Mobile Top 10 RISKS 2014 109

1. 前言

1.1.目的

因應資安威脅層出不窮，技術服務中心過往著重於資安事件之事中處理與應變，亦強調整體資安防護能量建置，包含既有之政府組態基準(Government Configuration Baseline, GCB)建立、強化資安意識之社交工程演練與資安職能之開發。

而在政府資訊系統安全防護上，技服中心亦於 99 年發布「Web 應用程式安全參考指引與實作手冊」，提供政府對外服務網站之建置過程中，提供發展流程之遵循指引與實作規範供機關與委外廠商參考。

本指引針對安全軟體開發生命流程中之安全軟體設計進行深入介紹，結合軟體安全需求，有效識別軟體安全風險，並套用合適之控制措施以進行風險處理，作為後續開發階段應遵循之事項與後續系統驗證之依據，提供機關與單位進行安全軟體發展生命週期之推動。

1.2.適用對象

本參考指引適用於軟體發展領域之所有對象，包含一般主管、資安人員及資訊人員，並針對不同對象建議說明其使用效益。

- 一般主管，例如資訊部門主管或軟體專案管理者，為確保軟體開發專案或組織使用之現有系統的安全性，於自行開發系統時可使用本指引來計畫安全設計活動與人力分配規劃之參考，或於委外開發之軟體專案或系統時用於擬訂需求書或合約時參考使用。
- 軟體架構與設計者，如系統架構師與軟體設計師，參考這份指引介紹之方法論找出系統潛藏的資安弱點與可能面臨的安全威脅，進而設計相關防護措施以強化系統設計階段時之軟體安全特性。

本文件之智慧財產權屬行政院資通安全辦公室所有。

- 軟體開發者，透過本指引之介紹理解安全軟體設計之原理與其重要性，於實做時理解安全設計之精神，進而達到軟體安全品質之提高與安全開發意識之提昇的目的。

1.3.章節架構

第 1 章說明本指引之目的、適用對象及章節架構介紹。

第 2 章說明介紹各種安全軟體設計標準與方法論，如 MS-SDL、OWASP Software Assurance Maturity Model (SAMM)與 NIST SP800-64，作為本指引參考文獻。

第 3 章就安全軟體設計階段中，各階段進行的實務活動進行說明，「安全設計原則」，說明應該進行系統設計時，應該參考使用的設計原則。「執行攻擊面分析」，說明進行攻擊面的定義、識別與對應方式，包含如何進行攻擊面的衡量與評估，並進行管理等。「執行風險分析」說明軟體設計過程中，如何透過使用威脅建模(Threat Modeling)與架構風險分析(Architecture Risk Analysis)，進行系統架構與威脅的分析，並介紹通用性的安全設計原則與控制措施，提供軟體安全風險分析與控制。「安全設計審查」說明在進行一連安全軟體設計的實務活動之後，應確保安全設計符合需求階段提出的相關安全需求及安全設計，能滿足軟體安全的基準線。

第 4 章之案例分析，以常見之 Web 應用程式，以及行動裝置應用程式設計為例。示範如何使用 MS Threat Modeling 工具進行威脅分析，並選擇接受該威脅或套用控制措施，再經套用 DREAD 評鑑標準對威脅進行評分與計算權重，產出開發過程中對於風險威脅之分析與處理措施表，確保系統資安風險經此風險處理流程後，將資安風險緩解至組織可接受之層級，而過程中所產生之控制處理措施將回饋至系統需求文件中，作為後續功能驗收與確認之來源依據。

本文件之智慧財產權屬行政院資通安全辦公室所有。

2. 安全軟體設計標準與方法論

根據美國國家弱點資料庫(National Vulnerability Database, NVD) 統計，93%的弱點為應用程式層級之弱點。軟體可能符合所有功能上的需求，但是並不安全。

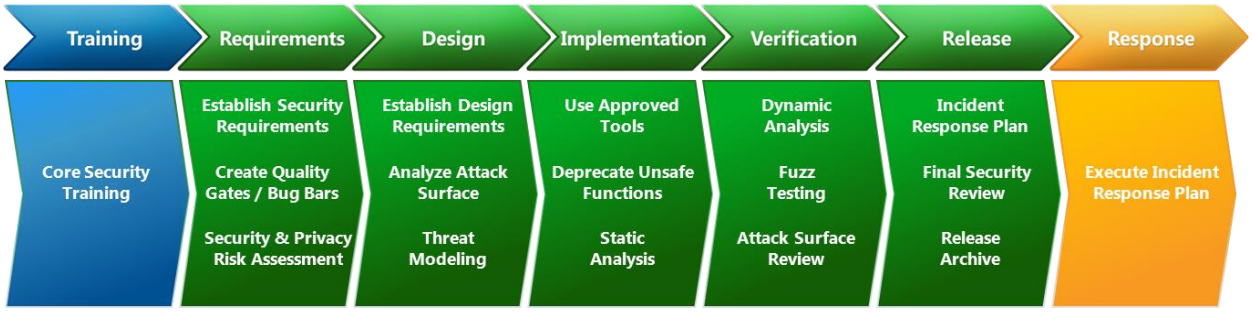
正確的安全軟體設計可以增進軟體品質， 根據研究機構 IBM Systems Sciences Institute 指出，軟體在設計階段將問題排除的成本是維護階段的百分之一[1]。

本章將會針對軟體開發生命週期中的設計階段進行介紹，進而導入安全軟體設計相關的標準要求，以及各家機構所提出的建議方法論進行介紹。

2.1.微軟「安全發展生命週期」SDL 與安全設計

2000 到 2001 年時，由於網際網路的發展，頻繁發生大量繁殖的病毒、蠕蟲等針對微軟作業系統的安全威脅。 Bill Gates 在 2002 年對微軟公司員工發出的備忘錄中，提到了高信賴度運算(Trustworthy Computing, TwC)的概念。重要的成果就是 2004 年推出的 Windows XP Service Pack 2，例如開始內建個人防火牆、增加了資料執行防止(Data Execution Prevention, DEP)、強化對 IE 瀏覽器外掛的管理及自動啟動系統更新機制等。後續微軟也逐漸意識到自身對資安威脅反應力不足的問題，必須找到正確的方法來從根本解決。故微軟於 2004 年開始，將自行發展的「安全發展生命週期」(Security Development Lifecycle, SDL)作為全公司實行的政策作法，該作法區分 7 階段，16 項必要實務活動，3 項選擇性實務活動，詳見圖 1。

本文件之智慧財產權屬行政院資通安全辦公室所有。



資料來源：[2]

圖1　微軟 SDL

關於 7 階段微軟「安全發展生命週期」SDL 於「安全軟體發展流程指引」中已有詳細的介紹，故本節中將會針對其中的設計階段(Design Phase)進行較為深入的介紹。

微軟「安全發展生命週期」SDL 將設計階段分為 3 個主要活動，分別為建立設計需求、減少受攻擊面與威脅建模。

2.1.1. 建立設計需求

軟體開發生命週期當中設計階段是最具影響力的階段，於是在設計階段中考量安全與隱私的需求就變得格外重要,若系統有任何安全性的問題存在，於設計階段進行解決所需的成本也是最低，因此凸顯出設計階段於安全軟體安全開發生命週期的重要性。此外開發團隊必須要能理解「安全的功能」的意義，往往許多時候，安全功能其實並不安全，正確的安全功能應能在滿足安全性的前提下正確執行，包含嚴格資料驗證、健全的加密技術實作等，若是系統資料驗證功能不夠嚴謹，加密技術實作上使用具有漏洞的演算法，皆不能當作安全的功能。

建立設計需求包含一連串的必要活動，包含安全與隱私的設計規格建立、規格審查與最低限度加密設計需求規格等，設計規格需描述使用者有可能接觸到的安全性或隱私性功能，如需要登入才能存取的敏感資料或需要使

本文件之智慧財產權屬行政院資通安全辦公室所有。

用者同意才能進行的高風險隱私性操作等。此外設計規格應描述特定功能或函式如何安全地實作，一個好的設計規格應該具有下列特性：

●精準的描述一個功能或函式的預期使用方法。

●描述如何以安全的方式實作此功能或函式。

2.1.2. 減少受攻擊面

減少受攻擊面與威脅建模相當類似，兩者的差別只在用不同的面向去檢視安全問題。減少受攻擊面是透過減少攻擊者可利用的威脅與弱點來降低系統風險，其實作手法包含切斷或限制系統服務的存取，實現最小權限的原則與縱深防禦的概念。

微軟「安全發展生命週期」SDL 建議減少受攻擊面應包含下列活動：

●檢視所有系統的進入點，如網路輸入/輸出、檔案 I/O 等。

●排序上述進入點的風險等級，如需授權操作與匿名操作、管理者權限或一般使用者權限、公用服務或內部網段服務及使用的通訊協定等，更多範例詳見表 1。

表1　擴大 vs 減少受攻擊面

擴大受攻擊面	減少受攻擊面
預設執行	預設不執行
建立新連線	中斷連線
UDP	TCP
匿名存取	授權存取

本文件之智慧財產權屬行政院資通安全辦公室所有。

擴大受攻擊面	減少受攻擊面
完全開放	條件式開放
管理員存取權限	一般使用者存取權限
外部網路存取	僅限內部網路存取
系統層級功能	非系統層級功能
統一預設設定	使用者選擇設定
大量程式碼	精簡的程式碼
弱的使用者權限控管	強的使用者權限控管

資料來源：[3]

- 檢視排序過後的系統進入點，依其風險等級依序進行減少攻擊面的設計，如建立防火牆規則、導入 WAF(Web Application Firewall)或使用加密傳輸等。

綜合以上可知道降低受攻擊面並非單純的限制服務而已，需從各個面向進行考慮，並且需充分了解降低攻擊面的重要性並不輸給安全程式開發本身。

2.1.3. 威脅建模(Threat Modeling)

威脅建模是透過分析來鑑別環境中可能發生的安全風險，允許開發團隊以結構化方式去考量並討論營運環境上可能發生的安全影響。威脅建模亦可以用在元件或應用程式等級，整個威脅建模的活動應由整個團隊於設計階段共同進行，包含產品經理、開發團隊與測試人員等。

本文件之智慧財產權屬行政院資通安全辦公室所有。

關於微軟「安全發展生命週期」SDL 的威脅建模提出許多方法論來協助開發團隊進行威脅建模，包含 STRIDE、DREAD 評鑑標準、主體對象矩陣與攻擊樹等，本指引會在第 3 章「安全軟體設計階段實務活動」進行更詳細的介紹。

2.2.NIST SP 800-64 與安全設計

美國國家標準與技術研究院(National Institute of Standards and Technology, NIST)提出的特刊(Special Publication, SP) 800 系列是一系列有關於資訊技術(Information Technology, IT)的安全標準。其中 SP 800-64 資訊系統發展週期的安全考量(Security Considerations in the Information System Development Life Cycle)，是針對系統開發生命週期所需要注意的安全事項進行探討。其協助機構建置基本的安全活動，將其整合至系統發展生命週期(System Development Life Cycle, SDLC)的建立，並能更符合成本效益、風險適當的安全控制識別、開發與測試。

SP800-64 將整個軟體開發的過程分成五個階段，分別為初始(Initiation)、需求與獲取(Development/Acquisition)、建置與評估(Implementation/assessment)、運作與維護(Operations/maintenance)，以及汰除(Disposal)，詳見圖 2。

本文件之智慧財產權屬行政院資通安全辦公室所有。



資料來源：[4]

圖2　系統發展生命週期示意圖

2.2.1. 評估系統風險

風險評估用來了解目前系統設計、需求與相關安全分析所得到的安全需求是否能有效的對抗可預期的系統風險。其結果能顯現出特定安全控制措施以提供足夠的防護或未來需要加強防護的區域。

評估系統風險活動應在設計規格被確認前執行，以確保其結果能轉化成安全設系規格或作為未來系統安全強化用的回饋。此外除了考量系統本身安全層面的問題外，亦需注意與其他系統界接的可能性，這代表可能有現有控制可被直接繼承使用或有額外的風險需被考量，這種情況下，設計者應該以更全面的視野來檢視系統可能的威脅與弱點。

本文件之智慧財產權屬行政院資通安全辦公室所有。

此階段預期產出的風險評估必須能了解現存的系統設計弱點，鑑別出系統限制並了解商業與技術元件的威脅，此時先前的需求可經風險評估後，轉化為系統規格。同時重新檢視先前的安全活動，如商業衝擊分析(Business Impact Analysis)或安全分類(Security Categorization)[5]是否符合預期或需進行修改。

NIST SP 800-64 提到與風險評估的相關建議：

- 安全分類可透過鑑別不同的資訊類型來提供風險評估的初始資訊。
- 依據風險評估後結果，額外的安全控制或補償措施應被計畫與加入，以滿足資訊與資訊系統的保護需求。

NIST SP 800-64 提到風險評估實作時的建議：

- 內部人員的不當行為應視為實際威脅，如系統開發人員或系統管理人員等都應進行必要的風險評估，並透過獨立的人員進行系統稽核。此外應透過系統自動化方式持續監控內部資源，如進行紀錄的蒐集、稽核與分析等。
- 可定期透過如 NVD[6]等弱點資料庫檢視系統所使用相關元件是否有相關弱點並進行修補。
- 當系統由多個擁有者時，如跨領域系統(Different Domains)，需鑑別與強調共有與繼承的風險。
- 依系統複雜度與安全層級的不同，風險分析可以依資料流或資訊交換處進行追蹤。
- 其他繼承風險可透過評估系統供應鍊進行，以防止使用詐欺、盜版、未授權或木馬元件的可能性。

2.2.2. 安全控制措施的選擇與文件化

本文件之智慧財產權屬行政院資通安全辦公室所有。

系統開發的過程中安全控制措施可分為 3 個部分，第 1 部分為基本安全控制措施，泛指軟體開發過程中會考量到的安全控制；第 2 部分為依據系統本身特性需求，所導入的控制措施；第 3 部分為風險評估後的結果，作為安全控制措施的補充。安全控制措施的選擇過程中，需以組織層級的角度進行思考，以滿足系統開發所預期達到的商業目的，此外安全控制措施也必須遵循到法規與標準的需求。除此之外，安全控制措施的應在滿足保護資訊資產的前提下考量成本效益，系統安全與系統營運應達到平衡。

NIST SP 800-64 中建議，系統開發過程中所選定的安全控制措施應文件化於系統安全計畫中(系統安全計畫詳細請參閱 NIST SP 800-18[7])，其內容提供系統安全需求的概觀、安全控制措施的放置點及如何滿足安全需求等，此外安全計畫應描述安全控制措施在不同的作業環境下如何實作，以及任何使用上的限制等。

NIST SP 800-64 提到與安全控制措施的選擇與文件化的相關建議：

- 一旦安全控制措施選定完畢，系統安全措施需求應加入系統安全計畫中。
- 風險評估為鑑別安全控制措施是否能滿足風險接受層級的主要工具。

NIST SP 800-64 提到風險評估實作時的建議：

- 透過安全需求矩陣的方式，讓開發人員與安全設計人員可以檢視每一項安全控制措施是否如設計預期所實作。
- 系統安全需求應以規格的方式呈現，而安全控制措施應該在軟體開發生命週期的主要活動中進行審查。
- 任何新的功能性需求都可能帶來新的安全考量，所以當系統功能進行變更時，皆應進行風險分析，以確保讓未知的可能風險進入系統中。

本文件之智慧財產權屬行政院資通安全辦公室所有。

- 更詳細的安全防護需求說明有助於確保安全控制措施與方法，在上線前被測試過，每一個文件化的安全需求，皆應有對應的測試案例被設計與執行。

- 安全控制措施的考量不應該單向思考，應適當考量多個元件間交互作用所產生的結果，如網頁伺服器與資料庫所組成的系統等。當控制措施文件化時，可以通盤考量這些因素，將可降低測試時的成本。

2.2.3. 設計安全架構

系統安全應以架構層級的方式導入系統設計當中，安全架構設計上，一般可透過隔離或叢集式服務進行設計，其保護機制可分散於各獨立服務中或共用，保護的方式亦可以重複設計或獨立的保護層形式存在。系統層面的安全設計需通盤考量，包含使用外部服務、與外部系統的界接連通及不同面向的使用者等(如客戶服務與系統管理員)。此外 NIST SP 800-64 建議在設計安全架構時，一併考量發展系統審查機制，其目的是在於定期追蹤各高風險工作流程，包含各種元件的活動紀錄，例如網頁應用程式、資料庫與網頁伺服器等，其紀錄無須將所有資訊都全部收集，應以可達到發現安全漏洞或系統錯誤目的即可。

設計安全架構應產出安全整合的詳細資訊，指出系統中何處需設計與實作安全機制，透過圖像化的方式協助了解安全控制措施的運作原理與具體實施方式。若有共用的服務，應以表格形式紀錄在安全架構設計中，並指出其共有的風險。

NIST SP 800-64 提到與設計安全架構的相關建議：

- 系統安全架構應為系統文件的重要元件，應在不同的階段進行審查與維護。

本文件之智慧財產權屬行政院資通安全辦公室所有。

●風險評估、安全測試與安全審查之結果應作為安全架構設計是否有效的依據進行檢視。

●系統安全計畫應將系統安全架構以摘要的方式進行描述。

●安全需求分析應提供詳盡的資訊，以利架構設計時可以系統層級進行檢視，判斷其導入系統後是否能如期運作或有不必要的重複工作。

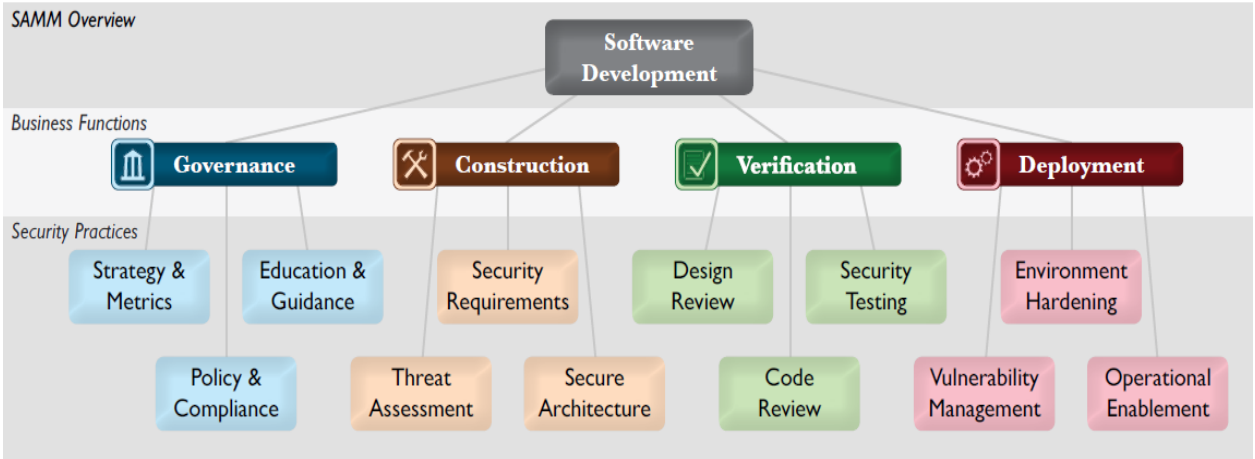
NIST SP 800-64 提到設計安全架構實作時的建議：

●設計安全架構可以有效的補足安全需求可能遭遇到的實作問題，此外可鑑別出重複的控制項目，以系統架構的方式進行解決。

●透過展示系統安全邏輯的方式，有助於鑑別是否需增加額外的控制措施。

2.3.Software Assurance Maturity Model (SAMM)

Software Assurance Maturity Model(SAMM)是由 Open Web Application Security Project(OWASP)組織所提出來的開源架構，其目的在協助面對不同風險威脅的組織，制定與實作相對應的軟體安全策略。SAMM 的基礎是建立在將核心商業機能與套用安全實務的軟體開發進行結合，詳見圖 3。



資料來源：[8]

圖3　SAMM 架構圖

本文件之智慧財產權屬行政院資通安全辦公室所有。

SAMM 將軟體開發分成監管(Governance)、建造(Construction)、驗證(Verification)與部署(Deployment)等 4 個階段，並將這 4 個階段細分為 12 個核心活動，並提出各活動中如何強化軟體安全的實務建議，其中每個實務活動又會分為 3 種層級，層級越高代表安全程度越高，這樣分級的用意是在於讓意圖強化軟體安全開發組織能循序漸進地加強，SAMM 認為意圖發展安全軟體開發的組織皆應遵循這些建議，逐漸加強，最後以達到最高層級的安全開發等級。

雖然 SAMM 本身為一個成熟度模型，但其中在各個階段的開發實務活動中，皆有針對各種層級的安全開發進行實務上的建議，值得作為安全開發的參考，本指引基於「安全軟體設計指引」之範圍將會針對建造階段中 3 個實務活動及驗證中的設計檢視活動進行介紹。

2.3.1. 威脅評鑑

威脅評鑑實務活動專注在鑑別與了解各種專案層級的風險，基於不同的軟體功能與營運環境的特性，風險也會隨之改變。面對各種威脅與可能的攻擊行為，從組織整體的角度來進行往往能更有效針對各安全議題進行判斷與排序。此外風險接受的決策也應以組織的商業目的為主。

SAMM 認為，遵循其所提出的實務建議，各組織可從簡單的威脅建模開始慢慢建立出更完整的威脅分析與權重方法，與時漸進發展後，最終將可達到高成熟度的安全軟體開發層級，與安全控制緊密結合且通過各種外部帶來的威脅考驗。SAMM 所提出的威脅評鑑等級表，詳見表 2。

本文件之智慧財產權屬行政院資通安全辦公室所有。

表2　威脅評鑑等級表

	等級 1	等級 2	等級 3
目的	鑑別與了解針對組織與各獨立專案的高威脅	增加風險鑑別的精度與強化各專案的認知	充分的將控制措施導入，以對應內部及第三方軟體的威脅
建議活動	▪建立與維護各系統的威脅模型 ▪從系統架構建立攻擊行為剖繪	▪建立各專案的誤用案例 ▪替威脅採用或建立一套評分標準	▪精準評估使用第三方軟體的可能風險 ▪透過控制措施有效對應威脅建模的及果
評鑑方法	▪是否有將組織內多數的系統所遭遇的可能威脅文件化 ▪組織是否有了解並文件化自己面對的攻擊者類型	▪專案團隊是否定期分析各功能性需求的可能誤用行為 ▪專案團隊是否使用任何方法評分各種威脅 ▪業主是否了解相關威脅與評分	▪專案團隊是否有特地考量外部軟體所帶來的風險 ▪所有的防護與控制措施是否能列出並對應到威脅
預期結果	▪高度了解可能產生負面後果的因素 ▪增加各專案團隊的威脅認知 ▪替自己組織所面臨的威脅歸檔	▪每個專案都能深入了解可能的威脅 ▪使用評分標準來替威脅處理進行更正確的判斷 ▪透過威脅評分來適當分配開發人力	▪對每一個軟體專案有更深入的威脅剖繪認知 ▪在每一個軟體專案中精確的將威脅與安全功能對應 ▪基於每個軟體專案的商業機能致力發展相關文件檔案

資料來源：[8]

本文件之智慧財產權屬行政院資通安全辦公室所有。

2.3.2. 安全需求

安全需求實務活動著重在以安全的角度鑑別軟體的預期行為。透過專案層級的分析活動，安全需求可從高階的商務目的開始著手，當一個組織有了新的商業目時，可能需要導入更高技術的系統安需求。當此活動到達一個成熟的狀態，此活動的監管可包含與供應商關係，確保供應商提供的軟體能滿足組織內的軟體安全規格，SAMM 所提出的安全性需求等級表，詳見表 3。

表3　安全需求等級表

	等級 1	等級 2	等級 3
目的	在需求階段明確的考量安全性	透過商業邏輯與已經針對風險強化安全性需求	要求安全需求活動應在所有專案及第三方軟體上執行
建議活動	▪透過商業功能導出安全性需求 ▪從需求評估安全性與法規遵循	▪針對資源與權限建立控管列表矩陣 ▪針對已知威脅指定特定安全需求	▪將安全性需求導入至供應商協議中 ▪將安全性需求納入稽核範圍
評鑑方法	▪是否大多數的開發團隊在開發過程中建立專案的安全性需求 ▪開發團隊是否有透過最佳實踐與法規遵循來建立需求	▪業主是否檢視過其擁有業務系統的控管列表矩陣 ▪專案團隊是否透過其他的安全活動的回饋來建立安全性需求	▪大多數的業主是否檢視過供應商對於安全性需求的協議 ▪各專案的安全性需求是否有被稽核
預期結果	▪讓商業風險與開發效益有對等的付出 ▪使用各領域的的最佳	▪清楚了解針對商業邏輯的攻擊情境 ▪依可能攻擊分配開發	▪替外部程式碼的安全期望建立基準線 ▪將各團隊在安全需求

本文件之智慧財產權屬行政院資通安全辦公室所有。

	等級 1	等級 2	等級 3
	實踐方式建立安全性需求 ▪讓業主的認知已有針對軟體可能面對的風險進行防護	資源到對應的安全性功能 ▪更有成效的學習如何在安全與功能取得平衡 ▪避免業主提出具有安全弱點的功能需求	上的努力成果資訊集中 ▪得以基於系統風險與預期的安全性需求分配支援

資料來源：[8]

2.3.3. 安全架構

安全架構的實務活動是著重在讓組織能夠從根基上便設計及打造安全的軟體系統。利用可重用的服務與元件，來達到強化軟體設計流程的目的，藉此大幅降低軟體開發過程中所會遇到的資訊安全風險。從使用簡單的軟體框架與明確的考量軟體設計原則開始，組織應能透過安全的設計模式強化自己的安全等級。此外此活動也鼓勵專案團隊開發與建立集中化的安全服務與架構。當此活動到達成熟階段，組織應該已有足夠的安全服務與元件，透過這些服務與元件的基礎打造最低風險與弱點的軟體。SAMM 提出的安全架構等級表，詳見表 4。

表4　安全架構等級表

	等級 1	等級 2	等級 3
目的	在設計階段主動加入安全性考量	將軟體設計流程導向使用已知的安全服務及預設安全的設計	正式控制軟體設計流程並驗證安全元件的使用

本文件之智慧財產權屬行政院資通安全辦公室所有。

	等級 1	等級 2	等級 3
建議活動	▪是否維護一份建議使用的軟體框架列表 ▪明確的在設計階段使用安全法則	▪識別並提倡安全服務與架構 ▪由架構面識別安全設計模式	▪建立正式的設計參考架構與平台 ▪驗證框架、設計模式與平台的使用
評鑑方法	▪開發團隊是否有建議使用的第三方套件列表 ▪多數的開發團隊是否有安全設計的意識並遵循	▪開發團隊是否宣揚與介紹共用安全服務 ▪開發團隊是否能提供不同架構上的安全設計模式	▪專案團隊是否透過中央控管的平台與框架打造軟體 ▪專案團隊對於安全架構元件的使用是否納入稽核範圍
預期結果	▪減少未預期的元件使用及重複開發 ▪增強業主對於增加第三方元件與框架會增加專案風險的意識 ▪建立開發過程中，主動將安全機制加入至設計的共識	▪詳細的將資產與角色對應，以鼓勵設計階段的責任分工 ▪可重用的設計可提供安全防護與功能的方便管理 ▪透過以建立安全設計技術來確保專安安全性	▪客製化開發平台，提供內建的安全防護 ▪將對安全開發的期望推廣到組織層級 ▪業主應能權衡安全性與商業功能之前的平衡

資料來源：[8]

2.3.4. 設計檢視

設計檢視著重在軟體設計評估及架構上的安全議題。這讓組織在開發階段早期發現架構上的安全議題，以防止維護時期需投入大量成本進行修補。安全檢視可先透過了解系統架構上的相關安全細節進行著手，接著發展出一套更正式的檢視方法來管理軟體架構上的安全機制。最終，成熟的設計檢視應能包含檢視資料層面詳細設計，並在軟體上線前將安全基準線強化至可接受程度，SAMM 提出的設計檢視等級表，詳見表 5。

本文件之智慧財產權屬行政院資通安全辦公室所有。

表5　設計檢視等級表

	等級 1	等級 2	等級 3
目的	針對每個軟體設計進行檢視，以確保已知風險降低的基準線	提供全面的最佳安全實務設計檢視評估服務	要求評估與驗證建立深入了解安全保護機制的產出
建議活動	▪鑑別軟體受攻擊面 ▪從已知的安全性需求分析設計	▪是否有對安全機制有完整的檢查 ▪向專案團隊提供設計檢視服務	▪建立敏感資源的資料流圖形 ▪建立設計檢視的通過門檻
評鑑方法	▪在軟體設計的文件中，開發團隊是否指出該軟體的攻擊邊界 ▪開發團隊是否有針對已知安全風險進行設計檢視	▪多數的開發團隊是否有特別針對設計中的安全機制進行分析 ▪多數的專案業主是否知道如何取得正式的設計評鑑報告	▪設計檢視是否有符合資料層級分析 ▪常規性的專案稽核是否有針對設計檢視設定基準值
預期結果	▪透過攻擊邊界對安全衝擊有高階的了解 ▪使開發團隊自我檢查設計是否有遵循最佳安全實務 ▪輕量化的檢視專案層級的設計	▪正式提供針對持續檢視安全設計架構的評估服務 ▪指出現有維護系統中的安全漏洞 ▪讓業主充分了解軟體開發中如何確保安全防護	▪系統設計階段將弱點環節放大檢視有助於工作切割 ▪組織層級的架構面資訊安全期望基準線認知 ▪比較專案間針對已知漏洞修補的效率與進度

資料來源：[8]

本文件之智慧財產權屬行政院資通安全辦公室所有。

2.4.軟體安全設計與風險管理

系統的風險分析可參考 NIST SP 800-30, Risk Management Guide for Information Technology Systems 並介紹如下：

Risk Management(風險管理)是資訊安全最重要的環結之一，每種 Access Control(存取控制)者必須依照風險管理、BIA(商業衝擊分析)等。
來決定資訊資產需要何種保護、需要何種機密性保護，因此風險管理可說左右著資訊資產的各項存取措施。

風險管理可以協助管理者識別與彙整總風險，選擇適當的緩解措施，針對組織訂定之可接受的殘餘風險等級，導入完整的風險管理處理流程，做為組織持續運作及改善使用。

風險管理中每一個 Owners 擁有具價值的資產，資產會有弱點，有弱點就可能有潛在的威脅(Threat Agents)，當潛在的威脅成為威脅，利用資產的弱點對資產造成風險，資產擁有者將導入控制風險的措施保護資產。
選定控制措施保護具弱點的資產降低資產的風險成為殘餘風險，但風險不可能為零，只能降低到可以接受的範圍。

舊版 ISO-27001 中亦規範資訊資產必須要經由風險評估(Risk Assessment)、風險分析(Risk Analysis)，取得資訊資產的價值及其脆弱度
在 SP 800-30 風險分析之中，將風險評鑑分為 9 個步驟：

- 系統描述(System Characterization)

  定義風險評估範圍，包含硬體、軟體與人員等。

- 威脅識別(Threat Identification)

  識別出所有資訊資產可能面臨的威脅來源。

- 弱點識別(Vulnerability Identification)

本文件之智慧財產權屬行政院資通安全辦公室所有。

識別出可能被威脅利用的弱點。

●控制分析(Control Analysis)

導入分析後的控制或是計劃，用來控制弱點產生的威脅。

●可能性測定(Likelihood determination)

針對弱點之威脅評估與制定可能造成衝擊的值。

●衝擊分析(Impact Anlysis)

針對資產之機密、敏感等級，依照其衝擊等級透過定性與定量分析，決定資產的價值及可能對組織造成之衝擊。

●風險測定(Risk Determination)

針對衝擊分析給予資產定義對應的風險等級。

●建議控制項(Control Recommendations)

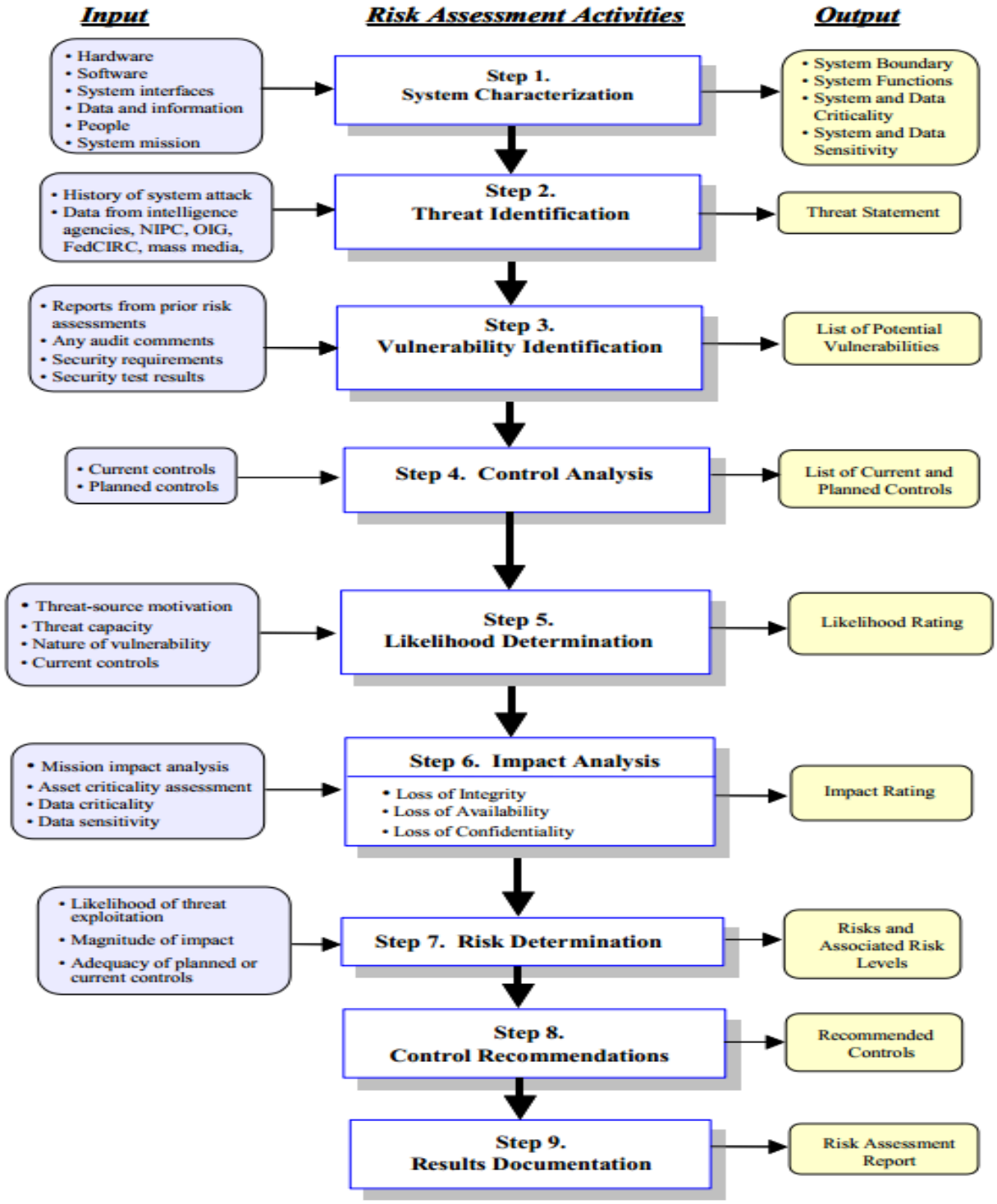
針對各風險等級提出成本效益考量導向的合適控制項。

●評估紀錄文件化(Results Documentation)

組織將風險評估出的結果文件化，並將本文件交由高階主管以協助各項風險任務的管理。

有關上述 9 個步驟之流程圖，詳見圖 4。

本文件之智慧財產權屬行政院資通安全辦公室所有。



資料來源：[9]

圖4　SP800-30 風險分析流程圖

本文件之智慧財產權屬行政院資通安全辦公室所有。

風險分析主要依據系統現有架構、已明確之功能需求與根據安全分類流程得到的最小軟體安全需求，能否有效減輕預期之安全威脅。風險分析結果應具體顯示針對高威脅風險所提供之風險控制措施，作為後續計畫使用。此過程需技術專家、使用者與業務專家以確保所有面向皆被考量與處理，安全風險評估亦應於技術規範被批准採用前進行，以納入額外技術成本之可能。

同時組織應考量系統自行開發與委外之可能性，建置一份可供重複使用之共同安控措施，並針對專案特性需求分析以減低額外之風險，

綜整上述安全軟體設計標準與方法論之論述，軟體安全風險亦為組織所應管理之風險，而安全軟體設計即為軟體安全風險管理，組織如何建立合適流程進行識別與彙整軟體安全風險，選擇適當的緩解措施，針對組織訂定之可接受的殘餘風險等級，導入完整的風險管理處理流程，做為組織持續運作及改善使用，即為安全軟體設計之核心精神，後續章節將針對實務活動進行介紹。

本文件之智慧財產權屬行政院資通安全辦公室所有。

3. 安全軟體設計階段實務活動

本章會針對安全軟體設計階段實務活動進行介紹,其中包含安全設計原則、攻擊面分析、風險分析、控制措施及安全設計審查。

3.1.安全設計原則

由第 2 章所提到的方法論中可得知整個軟體生命週期中設計階段的重要性和影響力，於是如何在這個階段中明確的考量安全與隱私的需求顯得格外重要。而以下是在系統設計階段時應該參考使用的設計原則，這些原則將盡可能地讓設計者設計出更安全的系統。

●最弱環節(Weakest Link)

攻擊者較可能攻擊軟體中的脆弱點，而不是戒備森嚴的部分。例如，有些加密演算法需要數年的時間才能夠破解，因此攻擊者將不會攻擊透過網路傳輸的加密資訊，相反的，網路傳輸的端點如伺服器才是容易受攻擊的目標。

安全從業人員經常指出，安全是一條鏈，且這條鏈的強度如同其最脆弱的一環。軟體安全亦同，整個系統的安全性等同於最弱元件的安全性。

●縱深防禦(Defense in Depth)

在軟體單一環節或進入路徑採用多重的安控措施，又稱作分層防禦(Layered Defense)。採用縱深防禦的原因為，單一的安控措施被突破或失效不會造成安全危害或只造成部分的危害。

實務上，可以從軟體常有的安全機制，進行縱深防禦的考量。一些例子如下：

－身分認證機制

本文件之智慧財產權屬行政院資通安全辦公室所有。

為避免帳號密碼容易被竊取，採用多重因素認證，例如增加使用 OTP 機制。

– 輸入驗證機制

在客戶端與伺服器端都對使用者輸入資料進行檢查。

– 錯誤處理

程式原始碼於方法(Method)中，使用捕捉錯誤的標準作法(例如，Try Catch)，另外，為避免程式設計師人為疏漏，應用程式伺服器設定錯誤顯示特定頁面，不顯示詳細錯誤訊息給使用者。

●最小權限(Least Privilege)

任何使用者或程序僅在被允許的最短時間區間內，被給與必需的、最小的存取權限，以完成其作業任務。

最小權限法則可以應用在檢視軟體中各角色，對功能與對資料的權限是否都設定為最小，也就是檢視軟體中的存取控制表(Access Control List)其權限設定是否適當。

最小權限法則的應用不只針對軟體或系統的使用者，也包含其他可能存取物件的程序或外部元件。實務上，請參考「攻擊面分析」，識別軟體的進入點，適當限制可存取性(Accessibility)。

●權限分離(Separation of Duties)

設計軟體功能時將條件設定在兩個或多個以上，且需要滿足所有的條件才能完成作業時，稱之為權限分離。權限分離的優點是，避免單一人員或主體的行為對整個軟體或系統帶來重大傷害。實務上，應識別軟體或系統中，哪些功能或行為會帶來最大的危害(例如，某功能可將所有資料刪除)，或某角色具有高權限(例如，管理員角色)，考量是否需進行權限分離。

本文件之智慧財產權屬行政院資通安全辦公室所有。

●簡化設計(Economy of Mechanism)

軟體設計越複雜，越容易產生安全漏洞。又稱作「保持簡單愚蠢」(Keep It Simple Stupid, KISS)法則。複雜性增加產生問題的風險，因此降低複雜度可以減少風險。軟體設計應該盡可能簡單明瞭，複雜的設計不容易被他人了解，在安全分析中也更不容易被找出問題。實務上，可採用以下作法以避免設計過於複雜：

– 模組化的設計

將整個軟體或系統切分成多個較小的單位或模組，模組的功能單一或較明確，具有物件導向的高凝聚力(Highly Cohesive)，與其他模組則具備低耦合度(Loosely Coupled)。

– 可重複使用的元件與服務

當軟體中一個通用的功能或原始碼需要被重複的呼叫使用，將其撰寫為可重複使用的元件或服務將有助於保持設計簡單。

– 減少不必要的功能與服務

將不必要的功能去除，減少設計實作不必要的功能服務後，又將其關閉的作法。

●安全故障(Fail Secure)

軟體發生錯誤或故障時，預設狀態為不允許存取，且維持機密性、完整性與可用性。此項法則與軟體的「錯誤及例外處理機制」有密切的相關。軟體中重要的功能或交易行為皆應設想發生錯誤的狀況，並考慮在錯誤的狀況下，各項安全機制是否還處於有效的狀態下：

– 存取控制

本文件之智慧財產權屬行政院資通安全辦公室所有。

發生錯誤時，被存取的物件或設定的狀態應為預設不允許存取。當錯誤次數高於一定水準時，考慮加以鎖定，不允許繼續嘗試存取。

– 密碼學應用

發生錯誤時，重要的機敏資訊是否仍保有機密性與完整性。

– 輸入驗證

發生錯誤時，對於輸入資料的驗證機制必須仍然處於有效的狀態下。

– 日誌紀錄

考慮發生錯誤時，需要記錄哪些資訊，是否需要進行通知，以及避免顯示詳細資訊給使用者。

●完全仲裁(Complete Mediation)

每一次主體存取物件時，都重新檢查其合法授權。這樣的作法通常無法被使用者接受，因為頻繁的要求使用者進行認證，軟體的易用性(Ease of Use)將降低。故軟體通常採用於登入或第一次存取物件時，檢查身分認證並給予授權，同時將其結果以使用快取機制暫存憑據(Credential)作為後續存取行為時使用。但是快取憑據的方式又使得攻擊者可以劫奪憑據重送的手法，偽冒合法使用者欺騙該軟體。因此實務上應考量軟體中有哪些重要的物件或功能，在每次存取時，特別重新要求使用者的身分認證及合法授權，以避免重送攻擊的危害。

●開放設計(Open Design)

安全設計不應依賴「隱藏式的安全」(Obscurity)。「隱藏式的安全」指安全性建立於別人不知道安全作法為何。實務上常見到，開發者以為將機敏資訊或安全機制藏於原始碼中，編譯後成為執行檔或二進制檔案後，就可以保持機密性，這樣的作法就是依賴隱藏式的安全。一個開放設計的例子

本文件之智慧財產權屬行政院資通安全辦公室所有。

是，著名的加密演算法，其公式皆為公開，密文的安全性建立於金鑰的機密性，而非演算法的機密性。總是假設攻擊者知道所有的設計與程式原始碼內容是較好的作法。

●使用現存元件(Leveraging Existing Components)

重複使用現有的、經過安全測試或實證的元件，因此得以避免增加新元件所產生的風險。實務上，軟體專案評估採用一項技術或元件時，除了其功能是否符合需求，也應考慮該項技術的安全性，以及過往是否發生安全事故。若軟體專案考慮採用某項剛推出不久的新技術，由於新技術往往較為強調新穎的功能，容易忽略安全性，因此更應審慎評估。

●防範單點失效(Single Point of Failure)

安全設計應確保軟體不會有單點故障或錯誤造成全面停擺的可能。防範單點失效與軟體的可用性相關，為達成高可用性的目的，實務上通常採取冗餘(Redundancy)方式進行備援處理，採用集群或主從架構等方式，當系統中單一的點發生失效時，其他的點可以接手或持續作業，因此將不會造成整體服務中斷。

●最少共用機制(Least Common Mechanism)

盡可能減少適用於所有使用者或角色的機制。共享的機制通常代表共享的資料，必須被很小心的設計以避免資訊流破壞安全性。另外，由於服務所有使用者或角色的機制，為了達成不同的需求，往往開放最多的功能以涵蓋全面，常常使其中某些角色取得不必要的權限。實務上，例如使用者登入用的前台身分驗證機制，與作業人員登入的後台身分驗證機制，不會設計成同一介面，會將兩個機制分開，以避免攻擊者嘗試登入後台、取得較高權限的風險。

●可接受度(Psychological Acceptability)

本文件之智慧財產權屬行政院資通安全辦公室所有。

考量安全機制對於人員的可接受度。良好的安全機制應該盡可能的設計為容易使用、不影響原先的存取,以及盡可能作到讓使用者感受不到其存在,以增加轉換與接受的程度。實務上,安全機制常會影響到軟體的易用程度,使得步驟增加或是額外的動作,但應該儘量將影響最小化在合理範圍內。

3.2.安全設計模式

軟體設計的過程當中,往往會重複遭遇到相同的特定問題需,為了解決這些常見且重複的問題,有經驗的設計者便提出適合解決該問題的設計方式,這種方式在軟體工程中便稱之為設計模式。

設計模式並非已完成的設計,開發人員並無法直接將其轉化成程式碼或功能,其在軟體設計中所扮演的角色為一種解決特定問題的方法描述或模板,設計者可以透過套用這些設計模式來解決設計過程中遭遇的問題。此外設計模式往往已是解決特定問題的最佳實踐,但並不代表設計模式是完美的。實際上所有的設計模式雖可解決其所對應的特定問題,但同時設計模式也會帶來相對應的限制與缺點,設計人員在套用設計模式的過程當中,並不應盲目套用設計模式,而需根據系統需求與整體考量進行規劃。

安全設計模式顧名思義變為針對解決軟體安全問題所提出的設計模式,此概念最早於 1997 年 Joseph Yoder and Jeffrey Barcalow(以下簡稱 Yoder and Baracalow)的論文[10]中被提出,如今隨著軟體開發的發展,許多的設計模式皆以被市面上常見的開發技術與開發框架所採用,基於安全設計原則中的使用現存元件(Leveraging Existing Components),建議使用者仍需依據自己使用的技術與框架進行安全設計模式的開發與使用。

本節將參考「Joseph Yoder and Jeffrey Barcalow. Architectural Patterns for Enabling Application Security」[11]與「Ronald Wassermann and Betty H.C. Cheng. Security Patterns」[12]兩篇論文中所提出的安全設計模式進行介紹。

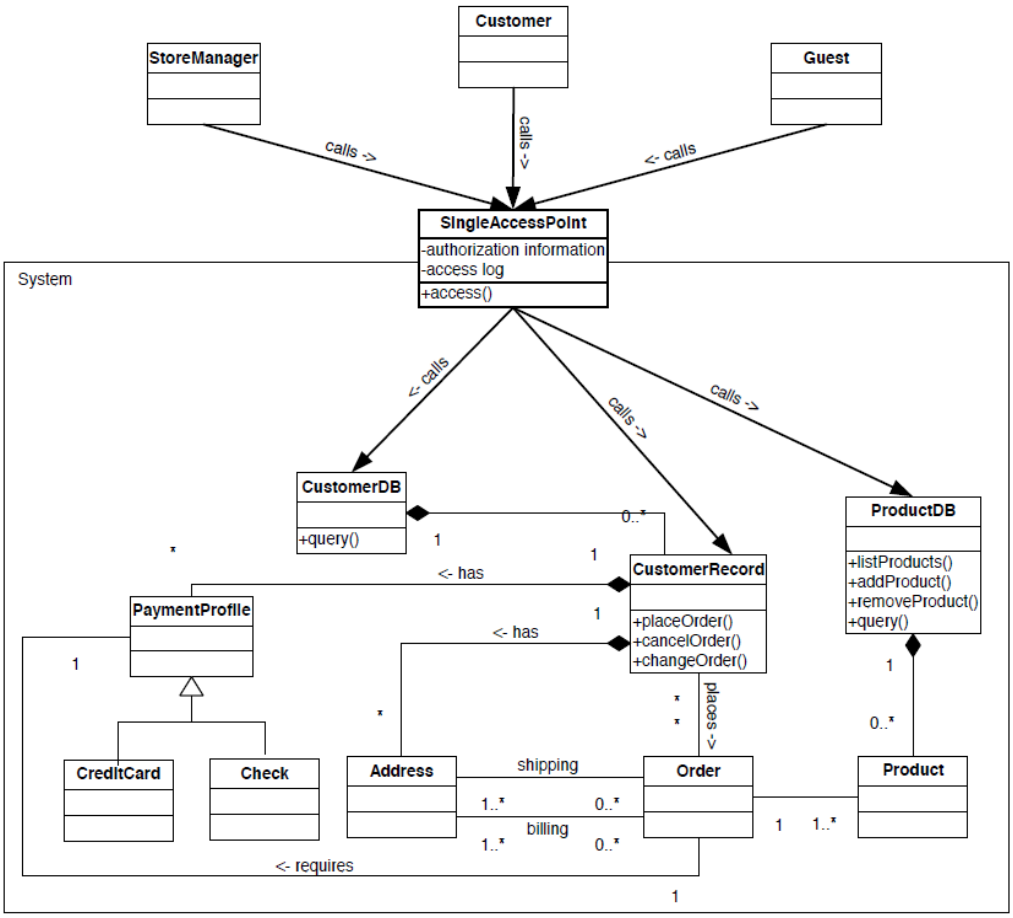
本文件之智慧財產權屬行政院資通安全辦公室所有。

●單點存取模式(Single Access Point)

單點存取(Single Access Point,簡稱 SAP)的概念為將所有的外來存取行為限制在單一通道中，以便進行管理與控制。

– 案例說明

案例情境為一網路商店系統，該系統包含前端的購物網站以及後端的管理介面。在套用單點存取模式後，無論是管理人員或客戶皆必須透過單一的存取介面才能與網路商店系統溝通，詳見圖 5。



資料來源：[11]

圖5　單一存取模式範例-網路商店系統

本文件之智慧財產權屬行政院資通安全辦公室所有。

單一存取模式與信任邊界概念是一致的，開發人員往往在系統規劃的過程中畫出信任邊界將對外接口統一至單點存取，透過搭配防火牆或網頁防火牆，讓所有的資料流皆經過該硬體設備，達到單一存取的目的。

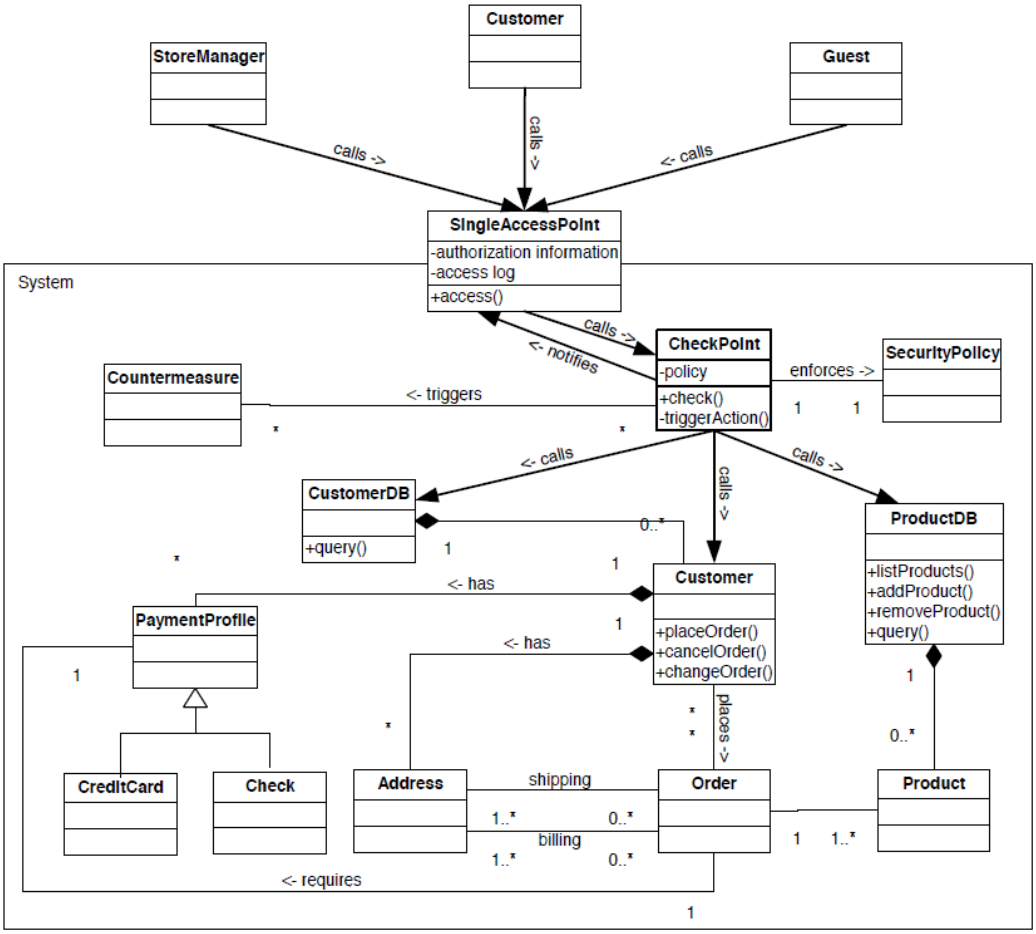
●檢查點模式(Check Point)

檢查點(Check Point)的概念在於搭配單點存取模式，將單點存取中驗證請求與訊息合法性抽出作為獨立的元件，所有出入的訊息皆可在檢查點進行驗證，並可導入相關問題的對應措施。

– 案例說明

承上網路商店案例，檢查點負責與單點存取(SAP)進行互動，負責檢查訊息的合法性、操作是否符合權限等，詳見圖 6。

本文件之智慧財產權屬行政院資通安全辦公室所有。



資料來源：[11]

圖6　檢查點模式範例-網路商店系統

檢查點模式於 Java EE 環境中等同於 Filter 機制，常見安全網頁應用程式開發中，開發人員會透過 Filter 實做身分驗證、權限控管以及輸入驗證等功能，所以除了善用此機制外，使用可靠的檢查機制更為重要。

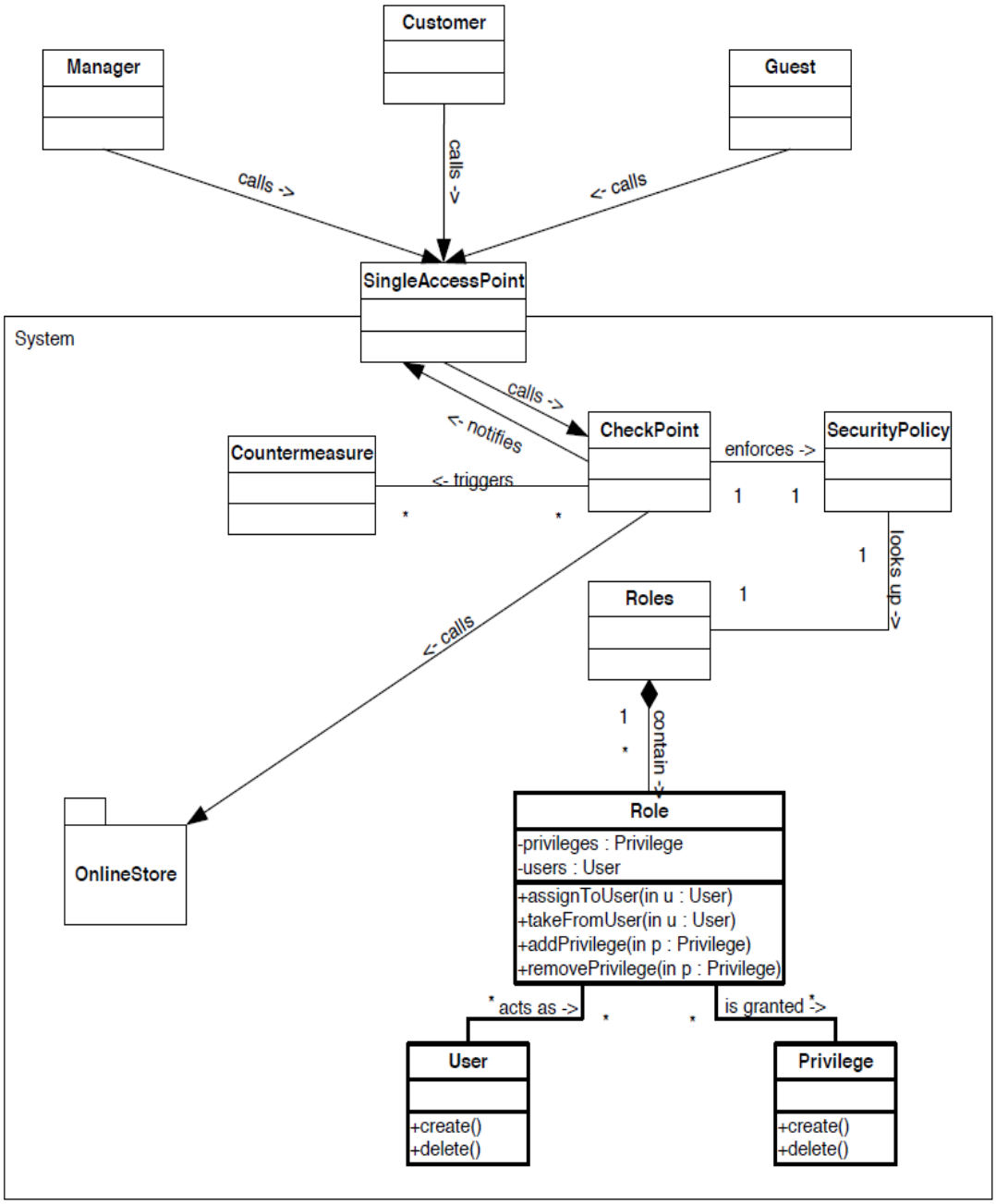
- 角色模式(Roles)

角色(Roles)模式亦稱為角色權限控管(Role-based Access Control)，此概念在於賦予每個使用者對應的角色權限，透過角色來對應所對應的權限。使用此模式後，無須針對每個使用者進行權限的設定，而是針對該使用者所賦予的角色進行管理即可。

本文件之智慧財產權屬行政院資通安全辦公室所有。

– 案例說明

承上網路商店案例，檢查點在檢查請求的合法性時，透過對照發角色權限判斷請求之合法性，詳見圖 7。



資料來源：[11]

圖7　角色模式範例-網路商店系統

本文件之智慧財產權屬行政院資通安全辦公室所有。

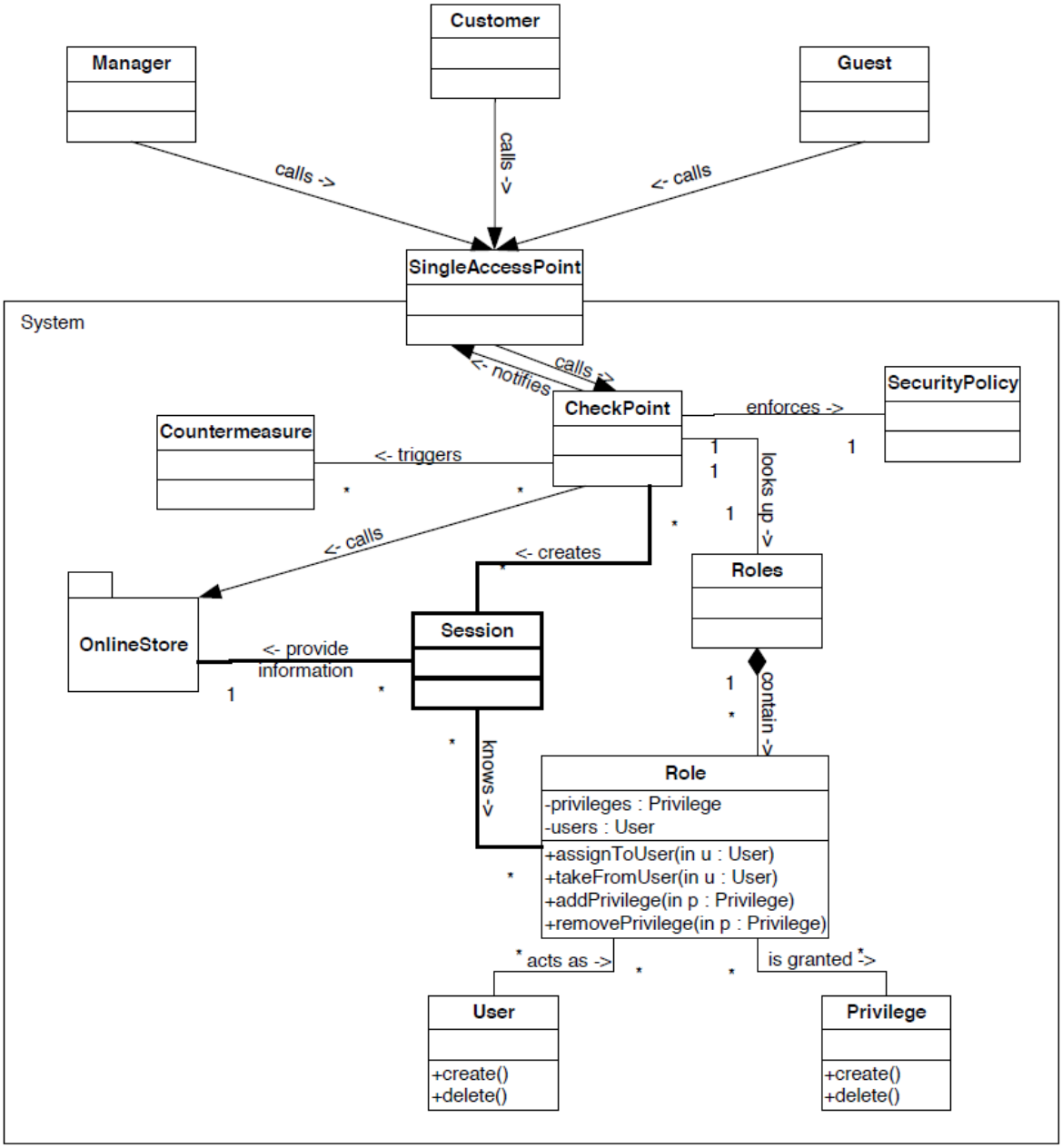
●會談模式(Session)

會談模式主要的概念在提供系統全域取得使用者的資訊之介面，方便讓系統可以在程式的任何一個區塊獲得使用者資訊，進而達到紀錄與權限控管之目的。

– 案例說明

承上網路商店案例，當檢查點接收到請求時，可以透過會談模式所提供的會談物件取得請求者相關的權限，藉此判斷請求得合法性，詳見圖 8。

本文件之智慧財產權屬行政院資通安全辦公室所有。



資料來源：[11]

圖8　角色模式範例-網路商店系統

現今各大系統架構大多具有會談模式的概念在裡面，開發人員無須自行開發其架構，使用系統所提供的會談管控(Session Management)機制即可。

本文件之智慧財產權屬行政院資通安全辦公室所有。

●具錯誤提醒的完整檢視模式(Full View With Errors)

具錯誤提醒的完整檢視模式(Full View With Errors)即指系統將可能的操作選項提供給使用者，但當使用者進行操作時還是要經過檢查與權限驗證，若使用者錯誤操作或做出非法存取時，則會跳出錯誤視窗。此模式優點在於無須額外控管呈現層的呈現內容，將所有選項列出。邏輯層在操作的過程中在進行相關的安全判斷，降低開發成本。但此設計模式與現代安全軟體開發想法並不相同，並不建議開發人員參考此模式。

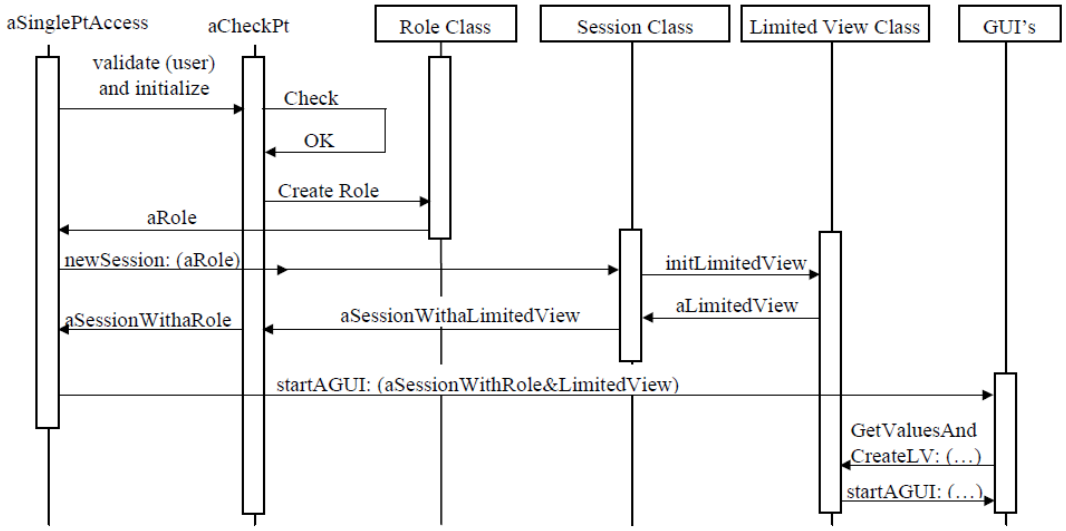
●受限檢視模式(Limited View)

與具錯誤提醒的完整檢視模式相反，受限檢視模式(Limited View)則將使用者所不允許的操作、選項與頁面等全部隱藏起來，此設計較符合現代安全軟體開發，一來不會讓使用者誤觸非法選項，也能讓系統提高更高的可用度，但開發人員仍需注意即使呈現層隱藏了非法的選項，仍然要在邏輯層加入相對應的輸入驗證與權限判斷，以防惡意使用者透過相關技術繞過進而危害系統安全。

●安全存取層(Secure Access Layer)

「Joseph Yoder and Jeffrey Barcalow. Architectural Patterns for Enabling Application Security」[10]中提出將上述 6 個安全設計模式整合後，即可構成為安全存取層(Secure Access Layer)，包含使用者透過單點存取(Single Access Point)存取系統，其中所有的操作皆經過檢查點(Check Point)進行驗證與查核。而檢查點搭配角色模式(Roles)可有效的針對使用者權限進行管理，並透過會談模式(Session)將使用者資訊與各個元件互動時使用，詳見圖 9。

本文件之智慧財產權屬行政院資通安全辦公室所有。



資料來源：[10]

圖9　安全存取層架構圖

3.3.執行攻擊面(Attack Surface)分析

攻擊面分析[12]讓開發人員注意到應用程式那些部分有可能遭受到攻擊，協助找出需要審查和測試的安全漏洞。攻擊面分析通常由安全架構師和測試人員來進行，但開發人員亦應去了解及監控那些由他們設計或修改的系統所產生的攻擊面。進行攻擊面分析所帶來的好處為：

●識別出系統那些部分需要檢視/測試安全漏洞。

●識別需要進行深層防禦的高風險程式碼-亦即系統所需要保護的部分。

●識別出當攻擊面改變後，需要做那些風險評估。

3.3.1. 定義攻擊面

攻擊面為描述攻擊者可以進入系統並取得所需資訊的各種不同的進入點，應用程式的攻擊面包含：

本文件之智慧財產權屬行政院資通安全辦公室所有。

●應用程式中資料/命令進出所有路徑。

●保護系統資源路徑的系統功能(包括資料連結和認證、授權、活動紀綠和驗證等)。

●所有在應用程式中有價值的資產，包含祕密金鑰、關鍵業務資料和個人資料等。

●保護資料的系統功能(包括加密驗證、資料完整性和安全控制等)。

可以使用角色和權限的關係來看系統的攻擊面，不同類型的用戶的數量會增加其複雜性。此外，擁有使用者權限最多與最少之用戶角色為系統中特別需要探討：

●未經身分驗證的匿名使用者，可被此角色所存取到的情境皆須預防與控制。

●權限過高的管理者(如：資料庫管理員、系統管理者)，任何使用此角色所進行的行為皆需驗證並記錄，以避免遭誤用與濫用。

3.3.2. 攻擊面的識別和對應

開始建立攻擊面基準線(Baseline)描述圖，從攻擊者的角度審查設計和架構文件。透過原始碼識別出攻擊者各種進入/離開的點，例如：使用者介面的表格和輸入欄位、HTTP 標頭和 Cookie、檔案、資料庫、郵件以及執行時期的參數等。

而這些不同的攻擊點可能總數相當龐大。為了管理上的方便，可以依照功能、設計和技術不同分類，例如：登入/驗證、管理界面、查詢和搜尋功能、業務流程以及 API 的傳輸介面等。

除此之外，還需要透過訪談系統開發者和使用者，以及再次檢視原始碼去識別出系統中有價值的資料(如保密、敏感性資料)。也可以透過掃描應用程

本文件之智慧財產權屬行政院資通安全辦公室所有。

式建立出攻擊面圖，像是使用 OWASP_Zed_Attack_Proxy_Project[13]、Arachni[14]、Skipfish[15]或其他商業動態檢測和漏洞掃描工具。

攻擊面分析和威脅建模中存在著一種相輔相成的關係：如果攻擊面改變了那就要重新進行威脅建模，而且可以透過威脅建模可以幫助了解應用程式的攻擊面。

3.3.3. 攻擊面的衡量和評估

一旦對應完攻擊面後，就必須識別出高風險區域，並專注在遠端進入的攻擊點，也就是與外部系統和網路之介面，特別是當系統允許匿名、公開存取。例如：Web 表單、來自外部網路的文件、舊的通訊協定及函式庫等。這些通常是最容易遭受到攻擊的地方，故須了解可以導入何種合適之控制措施來保護應用系統，例如：網路防火牆和應用程式防火牆等。

此外，當部署多個版本的應用程式、或是留下舊的、備份和未使用的程式碼時都會增加其攻擊面。因此加入原始碼管控和穩健的變更管理/配置的做法，是目前最有可能用來確保實際部署後攻擊面的理論之一。

3.3.4. 管理攻擊面

一旦對自己應用程式的攻擊面有基本了解後，可以利用它來逐步識別及管理風險。

網頁的建立通常會讓系統攻擊面變得明顯並增加許多新的風險，若於網頁中加入新欄位或加入一個類似的網頁,如此只增大攻擊面而非增加新風險，除非採用新的設計或新的框架。

若新增另一新頁面，遵循相同的設計，並使用相同的技術，那麼就很容易了解需要多少安全測試和審查。但若新增具網路上傳文件的網路服務功能，就可能帶來不同的風險。所以當加入的新功能或是變更是不屬於現存系統

本文件之智慧財產權屬行政院資通安全辦公室所有。

中的機制時，就代表必須要經過更徹底的風險評估，以了解會導致什麼樣的安全漏洞產生。

通常隨著加入更多介面、使用者類型以及和其他系統整合時會增加應用程式的攻擊面。可以透過簡化模型(例如：降低使用者層級的數量或是不儲存不必要儲存的資訊)，將未使用之功能關閉或導入操作控制(例如應用程式防火牆等)來降低攻擊面。

3.4.執行風險分析

風險分析應於安全軟體開發中的需求分析與架構設計階段進行，參與的人員角色，詳見表 6。

表6　參與人員

人員/角色	職責
Business Stakeholder	協助於需求訪談階段提供系統規格與需求制定，包含使用案例、誤用案例等
Security Analyst	協助進行高階架構風險分析與威脅建模
Software Architect	協助進行高階架構風險分析與實際底層之安全功能制定
QA Team	提供已知弱點等資訊協助風險分析，並針對系統安全功能進行測試與驗證
Development Team Leader	協助針對已知威脅之安全控制項目進行開發階段之實作檢視，確保控制措施有效落實

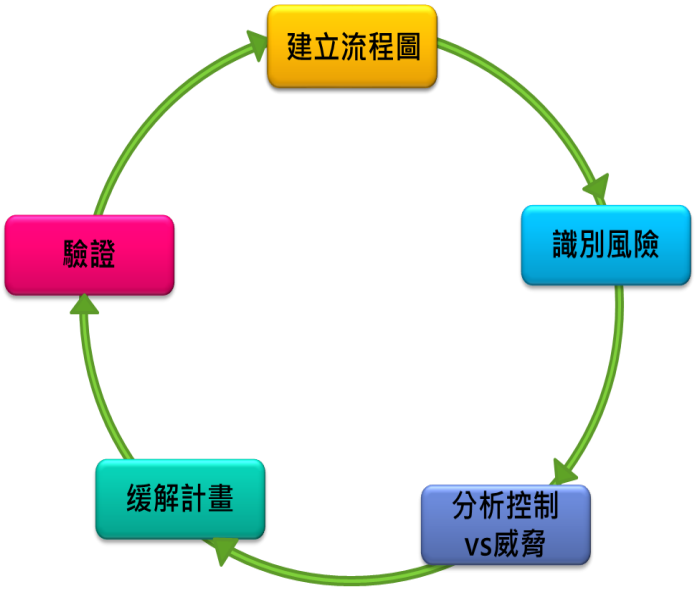
資料來源：本指引整理

風險分析主要依據系統現有架構、已明確之功能需求與根據安全分類流程得到的最小軟體安全需求，是否能有效減輕預期之安全威脅，風險分析結果應具體顯示針對高威脅風險所提供之風險控制措施，作為後續計畫使用。

本文件之智慧財產權屬行政院資通安全辦公室所有。

此過程需技術專家、使用者與業務專家以確保所有面向皆被考量與處理，安全風險評估亦應於技術規範被批准採用前進行，以納入額外技術成本之可能。

同時組織應考量系統自行開發與委外之可能性，建置一份可供重複使用之共同安控措施，並針對專案特性需求分析以減低額外之風險，而風險分析主要流程，詳見圖 10。



資料來源：本指引整理

圖10 風險分析流程

風險分析流程主要分為 5 個步驟：

●建立流程圖

這個步驟主要是要建立資料流程圖，利用資料流程圖定義出整個系統架構中的程序、資料流、資料儲存庫和信任邊界。

●識別風險

在這個步驟中利用各種風險分析的方式，如威脅類型表和攻擊樹狀圖，識

本文件之智慧財產權屬行政院資通安全辦公室所有。

別出整個系統有可能會遭遇到的風險。

●分析控制 vs 威脅

這個步驟主要是檢視目前已設計的控制和防禦機制，是否足以應付剛剛識別出的風險。

●緩解計畫

這個步驟的主要目的其實就是定義出威脅應變計畫，並將上一階段的安全需求列舉出具體可以進行測試的部分。

●驗證

這個步驟主要就是利用威脅建模的方式，將威脅的類型轉化成測試案例以驗證所設計的系統安全性部分是否無慮。

3.4.1. MS-Style Threat Modeling [16]

微軟提出 Threat Modeling 的方法論，整個威脅建模的流程如下：



資料來源：本指引整理

圖11 威脅建模流程

本文件之智慧財產權屬行政院資通安全辦公室所有。

整個威脅建模流程分為 6 個步驟：

●識別資產

識別出哪些才是系統必須保護的重要資產。

●建立架構概觀

利用簡單的圖表來記錄應用程式的整體架構，包含子系統、信任邊界和資料流。

●分解應用程式

將應用程式進行架構分解，包含基礎網路和基礎架構設計，目的在於為應用程式建立一個安全配置文件。這份文件的目的就是在應用程式設計、實作及部署時能夠發現弱點。

●識別威脅

留意攻擊者的目標以及應用程式的潛在漏洞，找出可能影響應用程式的威脅。

●記錄威脅

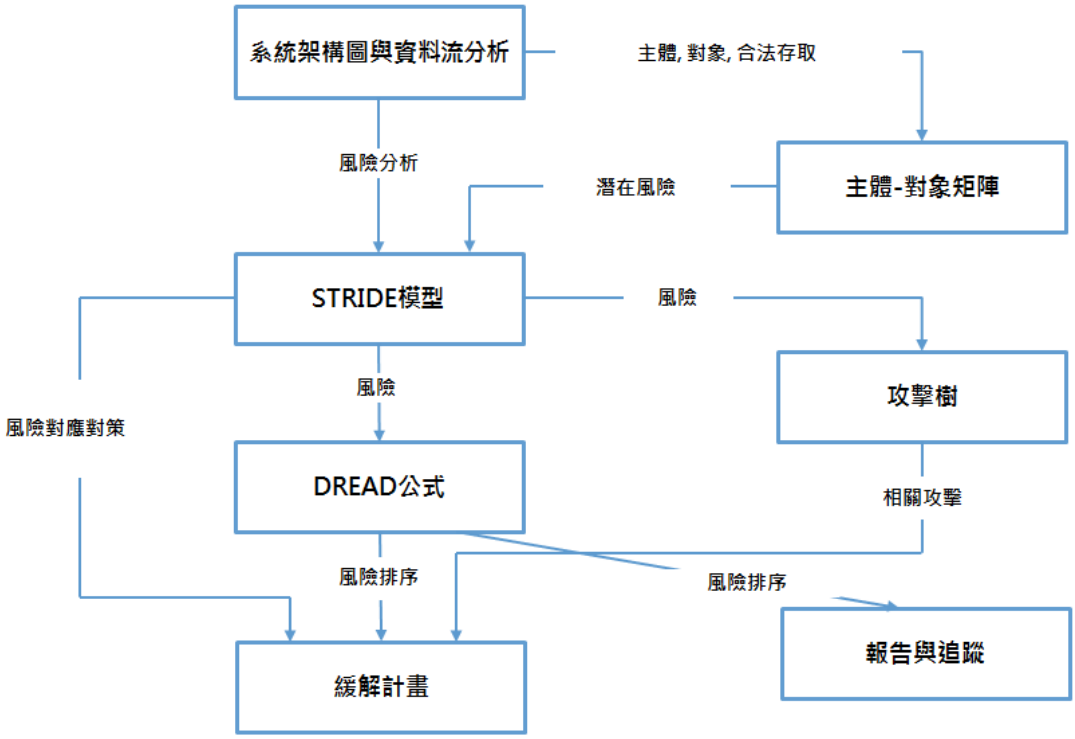
將識別出的威脅使用威脅的屬性定義和一般常見的威脅樣板記錄下來。

●評估威脅

評估所面臨的威脅，針對嚴重程度進行排序，並且優先處理優先權最高的。

有關整個威脅建模的流程，詳見圖 12。

本文件之智慧財產權屬行政院資通安全辦公室所有。



資料來源：本指引整理

圖12 MS-Style Threat Modeling 流程圖

●系統架構圖與資料流分析

一般的應用程式最基本可分為輸入、輸出與處理 3 部分，資料流程圖(Data Flow Diagram, DFD)描述資料在系統內的子系統間、系統與外部之間，資料來源、目的與儲存之間之相互關係，資料流程圖為結構化系統分析與設計所使用之標準描述工具之一，故使用資料流程圖可清楚識別與了解系統之所有資產、處理流程與相關內外部介面之互動關係。

而在資料流分析中，可以把資料流分為以下元素，而代表符號詳見表 7。

– 外部實體

由人員和其他外部系統所組成。

本文件之智慧財產權屬行政院資通安全辦公室所有。

– 程序

包含 DLLs、元件、服務、Web Services 和 Com 物件等。

– 資料流

包含函式呼叫、網路流量、遠端程序呼叫等。

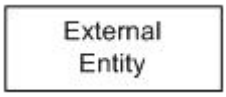
– 資料儲存庫

包含資料庫、檔案和共享記憶體等。

– 信任邊界

包含程序邊界和檔案系統等。

表7　資料流組成元素

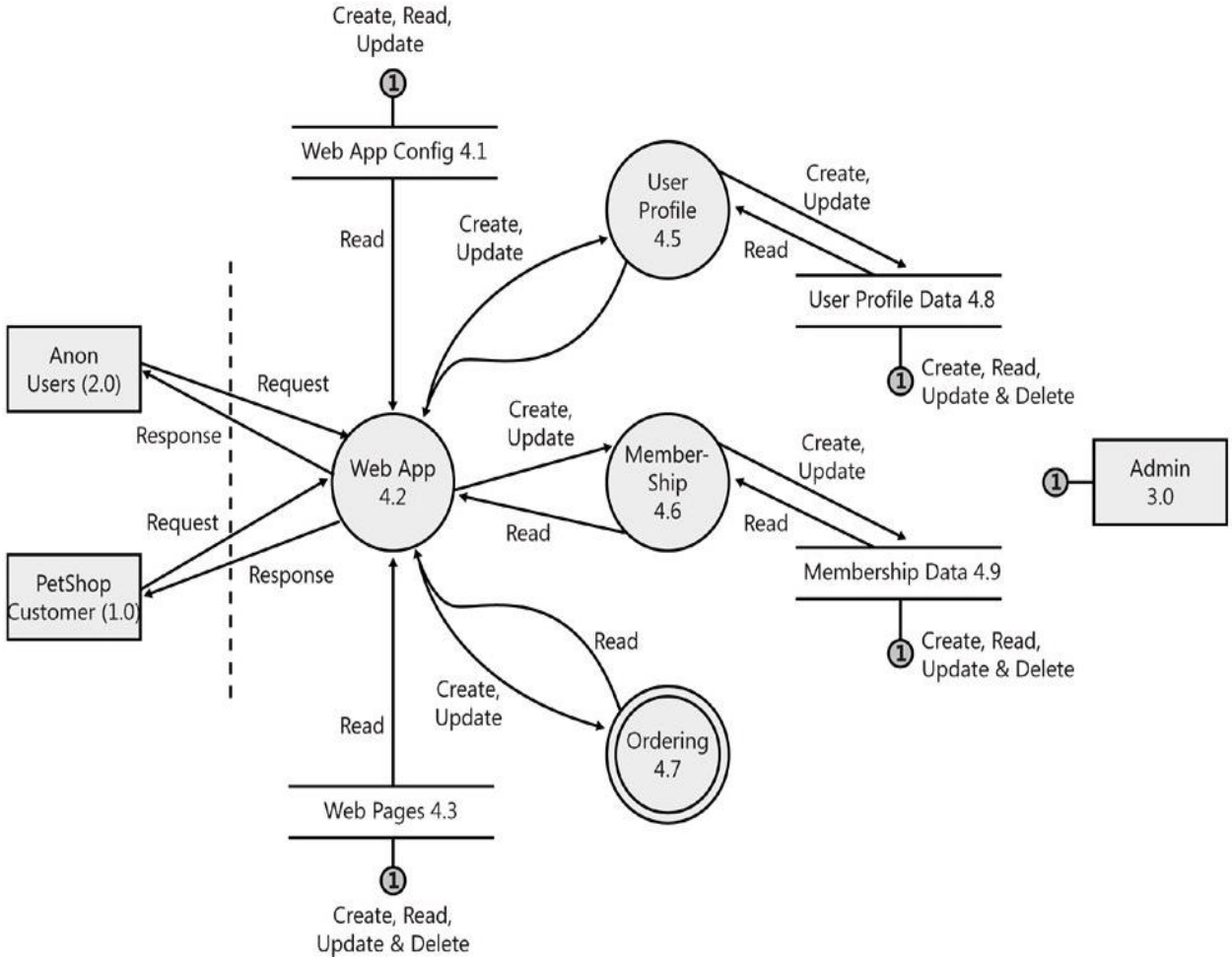
組成元素	符號
外部實體	
程序	
資料流	
資料儲存庫	

本文件之智慧財產權屬行政院資通安全辦公室所有。

組成元素	符號
信任邊界	Trust Boundary

資料來源：本指引整理

有關資料流程圖(Data Flow Diagram, DFD)之範例，詳見圖 13。



資料來源：本指引整理

圖13 Example of DFD

本文件之智慧財產權屬行政院資通安全辦公室所有。

透過繪製資料流程圖後，除可清楚識別與了解系統之所有資產、處理流程與相關內外部介面之互動關係，亦可作為製作主體-對象矩陣與 STRIDE 使用。

●主題-對象矩陣

透過分析出來的系統架構圖與資料流來識別出主體、物體與存取行為，再透過矩陣反轉找出系統的潛在風險。

●STRIDE 模型

將分析出來資料流和主題-對象矩陣所找出的潛在風險套用 STRIDE 模型得出系統會產生那些風險。

●攻擊樹

將 STRIDE 模型所得到的風險透過攻擊樹分析取得有可能的相關攻擊路徑。

●DREAD 評鑑標準公式

將得到的風險透過 DREAD 評鑑標準公式進行風險排序。

●緩解計畫

根據 STRIDE 模型所得到風險對應對策、DREAD 評鑑標準公式得到的風險排序以及攻擊樹得到的相關攻擊路徑去選擇相關的控制措施，制定符合的緩解計畫。

●報告與追蹤

將 DREAD 評鑑標準公式得到的風險排序去訂定追蹤報告，風險最高的列為重點追蹤項目。

本文件之智慧財產權屬行政院資通安全辦公室所有。

經過 MS-Style Threat Modeling 可以有效鑑別出軟體設計之風險，透過風險鑑別與評鑑決定接受風險或套用適當的威脅控制措施，將風險降至組織可接受之層級，後續章節將針對相關方法論進行介紹。

3.4.1.1. STRIDE

STRIDE 是一種識別威脅的方法，STRIDE 其實是由 6 個威脅類型的英文字首縮寫所組成(詳見表 8)。

表8　STRIDE

字首	代表含意	描述	相關安全特性
S	偽冒(Spoofing)	假冒為某人或某物	身分認證 (Authentication)
T	竄改(Tampering)	惡意的修改資料	完整性 (Integrity)
R	否認行為 (Repudiation)	使用者可以否認曾經進行某行為，沒有方法可以證明其行為	不可否認性 (Non-Reputation)
I	資訊洩漏 (Information Disclosure)	資訊被洩漏給不被預期可存取的個體	機密性 (Confidentiality)
D	拒絕存取服務 (Denial of service)	對使用者拒絕服務或降低服務水準	可用性 (Availability)
E	權限提升 (Elevation of privilege)	未正常授權取得權限能力	授權 (Authorization)

資料來源：本指引整理

本文件之智慧財產權屬行政院資通安全辦公室所有。

而系統資料流中的組成元素都有可能成為攻擊目標，但根據其性質，可能產生的威脅類型並不相同，以下列出不同的資料流元素所可能發生、相對應的威脅類型(詳見表 9)，也可以透過這張表思考系統有可能遇到的攻模式。而 V 代表資料流有可能發生的類型。

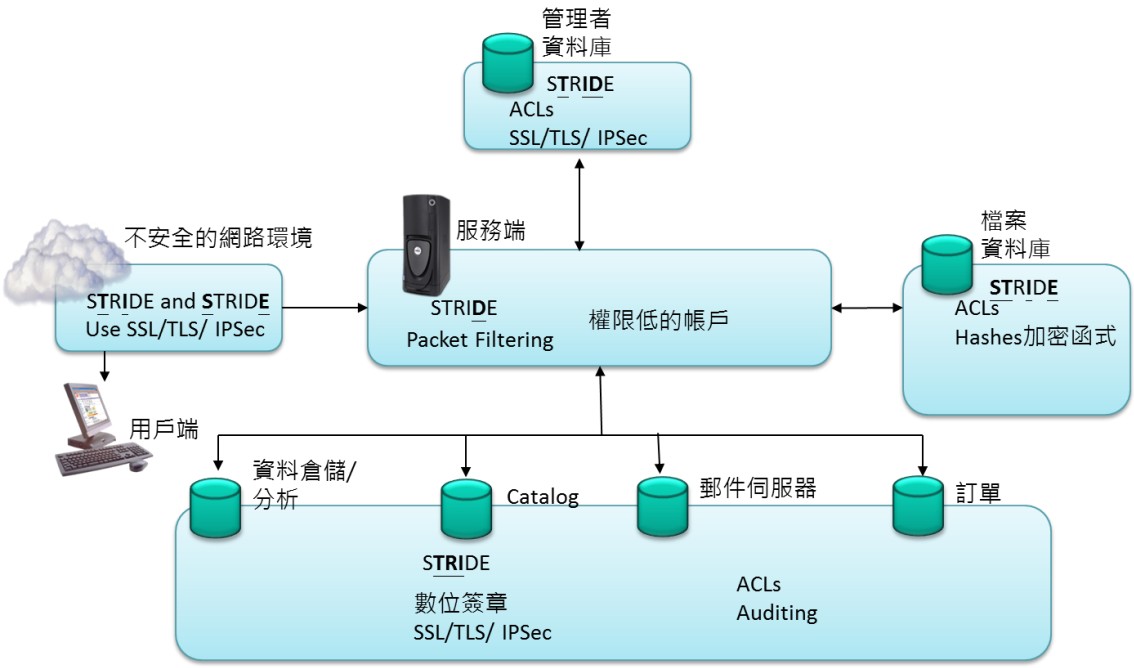
表9　資料流元素對應的威脅類型

威脅類型 / 組成元素	偽冒	竄改	否認行為	資訊洩漏	拒絕存取服務	權限提升
外部實體	V		V			
程序	V	V	V	V	V	V
資料流		V		V	V	
資料儲存庫		V	V	V	V	

資料來源：本指引整理

團隊可以將 STRIDE 模型應用到目前設計的應用程式裡，檢視每個元件間連結關係及元件本身是否存在著任何 STRIDE 的威脅。並將這些威脅紀錄下來，圖 14 描述一般伺服器有可能面臨到的 STRIDE 威脅以及相關的應變措施。例如用戶端在存取伺服器資料時可能因為網路環境的不安全，而面臨到資料可能遭受洩露或是竄改的風險，用戶資料也有可能被攻擊者偽冒並透過不正當方式取得未授權的權限。為了減輕這些威脅的發生機率，使用 SSL 協議、傳輸層安全性(TLS)以及 IPSec 協定進行身分驗證。

本文件之智慧財產權屬行政院資通安全辦公室所有。



資料來源：本指引整理

圖14　STRIDE 範例圖

3.4.1.2. DREAD 評鑑標準評鑑方法

DREAD 評鑑標準為計算風險數值所使用的公式，而一般用來計算威脅風險的方式如下[17]：

風險(Risk) = 發生可能性(Probability of Occurrence) X 商業影響(Business Impact)

由此公式可以得知，其實威脅發生的可能性再去乘上所造成的影響就會是該威脅所帶來的風險值。因此可以將 DREAD 評鑑標準套用在該風險公式上，在系統設計階段對於系統各項威脅，進行更具體的評估，而套用之後，具體的風險評估公式則會呈現為以下：

風險(Risk) = (可重製性+可刺探性+可發現性) X (可能傷害+影響人數)

有關 DREAD 評鑑標準，詳見表 10。

本文件之智慧財產權屬行政院資通安全辦公室所有。

表10 DREAD 評鑑標準

字首	代表含意	描述	相關安全特性
D	可能傷害(Damage potential)	如果此威脅發生，傷害有多大?	商業影響
R	可重製性 (Reproducibility)	重新產生針對此一威脅的攻擊的困難程度?	發生可能性
E	可刺探性 (Exploitability)	發動攻擊的困難程度?	發生可能性
A	影響使用者數 (Affected users)	受影響的使用者人數?	商業影響
D	可發現性 (Discoverability)	發現弱點的困難程度?	發生可能性

資料來源：本指引整理

而衡量的評估標準，詳見表 11，透過分數計算出各個風險的數值之後，再依照分數的高低進行風險排序，可以將風險數值總和評量為 12 到 15 的潛在威脅視為高風險，8 到 11 的視為中風險， 5 到 7 則是視為低風險。我們可以根據排序結果制定風險計畫，而風險計算的範例，詳見表 12。

表11 DREAD 風險值計算標準

項目	高(3 分)	中(2 分)	低(1 分)
可能傷害 (Damage potential)	攻擊者取得完整的機敏資料；取得系統最高權限	洩漏部分機敏資料	洩漏系統細節資訊
可重製性 (Reproducibility)	攻擊可以不停重製且不需要暫停時間	攻擊可以重製，但需要暫停時間	攻擊難以重製，或需要對弱點有深入知識才能重製

本文件之智慧財產權屬行政院資通安全辦公室所有。

項目	高(3 分)	中(2 分)	低(1 分)
可刺探性 (Exploitability)	不具有相關技能者也可以發動攻擊	具有相關技能者可以發動攻擊	需要對弱點有深入知識才能發動攻擊
影響使用者數 (Affected users)	所有的使用者	部分使用者	極低比例的使用者
可發現性 (Discoverability)	公開資訊已揭露攻擊手法及漏洞	已被找到相關的資訊，但漏洞尚未被揭露	極少用到的功能且使用者難以找出漏洞

資料來源：本指引整理

表12 風險計算範例

威脅描述	D	R	E	A	D	風險值	風險程度
攻擊者透過監控網路取得身分驗證憑證	3	3	2	2	2	12	高
應用程式遭受 SQL 資料隱碼攻擊	3	3	3	3	2	14	高

資料來源：本指引整理

可以針對整理出來的風險進行相關的因應對策，詳見表 13。

表13 因應對策範例

威脅描述	攻擊者透過監控網路取得身分驗證憑證
威脅目標	Web 應用程式的使用者身分驗證流程
風險等級	高
攻擊手法	利用網路監控軟體
因應對策	使用 SSL 做為傳輸用的加密通道

資料來源：本指引整理

本文件之智慧財產權屬行政院資通安全辦公室所有。

3.4.1.3. 主體對象使用矩陣(Subject-Object Matrix)

Subject-Object Matrix 主要用途為透過識別主體、物體與存取行為，並製作其正常使用情境的對應矩陣，並透過反轉正常情境之矩陣快速得到具威脅之情境矩陣。

●製作 Suject-object 矩陣

– 主體(Subject)主要為與系統互動之人員或、角色或功能模組。

– 物體(Object)為系統擁有的資訊與資產，包含常見的資料庫、檔案等。

– 存取(Access)為主體對物體之操作行為，如資料庫物件的新增(Create)、刪除(Delete) 、修改(Update)與讀取(Read)。

●矩陣反轉

上一步驟中所彙整之矩陣為系統設計中所允許之操作行為，故任何與此矩陣所不符合之項目皆可視為系統潛在之威脅，如透過反轉矩陣後可以列舉出所有的風險，以下為應用此矩陣之實例介紹。

以一系統為例，系統為一具交易功能之商業交易平台，此系統包含下列 Subject。

表14　風險分析範例系統角色表

人員/角色	說明
系統管理者	進行系統資料之設定維護與定期系統日誌之審視
登入使用者	經過帳號密碼登入驗證後之合法使用者，登入後可進行資料之修改與進行交易

本文件之智慧財產權屬行政院資通安全辦公室所有。

人員/角色	說明
一般使用者(未登入)	未登入系統之一般使用者，除公告類資訊外無法存取系統任何資訊
Log 紀錄模組	針對使用者之交易行為進行記錄

資料來源：本指引整理

而整理出來的 Object 之系統物件列表詳見表 15。

表15　系統物件列表

Object	說明
系統設定資訊	系統設定參數資訊
使用者帳號資訊	使用者個人資訊

資料來源：本指引整理

根據主體與物件之表產生下列之 Subject-Object Matrix(詳見表 16)，X 代表該主體對物體並無任何使用之權限。

表16　Subject-Object Matrix 範例

	系統資訊	使用者帳號資訊	交易紀錄
系統管理者	CRUD	CRUD	CRUD
登入使用者	X	X	自身紀錄 CRUD 他人紀錄 X
一般使用者(未登入)	X	X	X
Log 紀錄模組	X	X	X

資料來源：本指引整理

本文件之智慧財產權屬行政院資通安全辦公室所有。

CRUD 代表主體對物體的新增(Create)、讀取(Read) 、修改(Update)與刪除(Delete)，X 代表該主體對物體並無任何使用之權限。

表17　Subject-Object Matrix 反轉範例

	系統資訊	使用者帳號資訊	交易紀錄
系統管理者	X	X	X
登入使用者	CRUD	CRUD	自身紀錄 X 他人紀錄 CRUD
一般使用者(未登入)	CRUD	CRUD	CRUD
Log 紀錄模組	CRUD	CRUD	CRUD

資料來源：本指引整理

將該矩陣反轉後所得到之新的結果矩陣可顯示系統存在之安全威脅，包含：

●一般使用者可對系統管理敏感資訊進行存取行為(資訊洩漏)。

●使用者可存取到除了自己帳號以外之交易資訊(未授權之使用)。

●管理者無法存取應可存取之系統資訊(DoS, 可用性)。

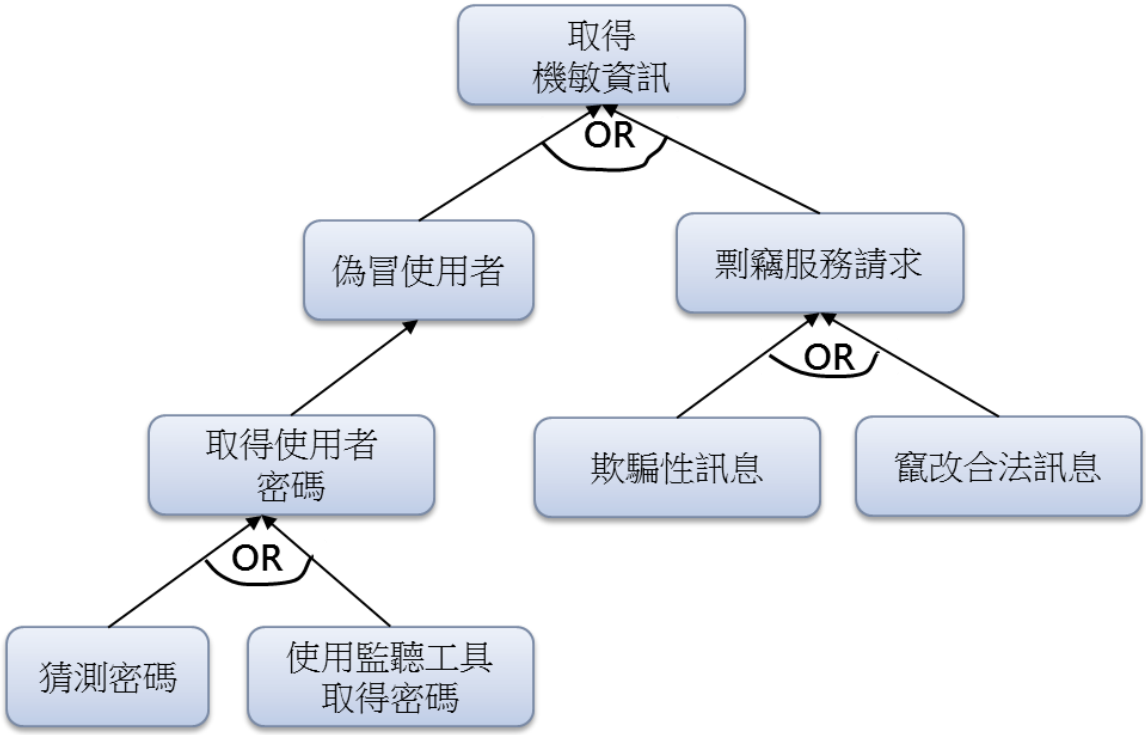
列出所有風險後，可依據 DREAD 評鑑標準方法論為風險進行分級，然後針對風險制定 Mitigation plan(緩和措施)。

3.4.1.4. 攻擊樹(Attack Tree)

攻擊樹狀圖(Attack Tree) [18]是由 Bruce Schneier 所提出用來分析資訊安全風險的一種方法，他將可能攻擊的目標利用視覺化呈現。將攻擊者的目標放置於樹狀結構的根節點(Root Node)，並就此目標的達成手段開始進行分

本文件之智慧財產權屬行政院資通安全辦公室所有。

支動作，要達成這目標的各項子目標則被稱為葉節點(Leaf Node)。OR 和 AND 則說明了成為攻擊方式的路徑條件，如果分支是以 OR 連接，代表其中一項成立即可發動攻擊，若是分支是以 AND 連接，則表示該目標所連接的各項葉節點都必須成立才行。而一個實際的攻擊樹狀圖範例，詳見圖 15。



資料來源：本指引整理

圖15 攻擊樹狀圖範例

由上圖可以得知攻擊者目標為取得機敏資訊，而就攻擊目標進行分解動作，可分為透過偽冒使用者或是剽竊服務請求這二個子目標來取得機敏資訊，再進一步往下分解以左邊分支為例，偽冒使用者就必須取得使用者密碼，而取得使用者密碼又可分為二種方式，一種是用猜測密碼的方式取得，另一種則是使用網路監聽工具取得使用者密碼。而從上圖整體，可以得知如果要取得機敏資訊，攻擊者可以透過猜測密碼、使用網路監聽工具、發出欺騙性訊息或是竄改合法訊息這 4 種方式來達成目標。

本文件之智慧財產權屬行政院資通安全辦公室所有。

可根據攻擊樹的每個葉節點進行量化，透過計算每個葉節點的成本，可以估算出攻擊者採用不同攻擊方式時所花的成本，試著去推算出攻擊者最有可能採用的攻擊模式。

3.4.1.5. 工具介紹

本節將針對微軟 SDL 官方網站所提供的 Microsoft Threat Modeling Tool 2014[19] (以下簡稱威脅建模工具)進行介紹。威脅建模工具是由微軟所開發提供，此工具提供清楚簡單的介面讓開發者使用，透過工具的協助，無專業資安背景的開發人員亦可進行威脅建模，進而強化系統安全度。

威脅建模工具可替開發人員帶來下列好處：

- 溝通協調系統安全設計。
- 透過可靠的方法論分析系統可能的風險。
- 針對資安議題進行建議與管理。

此外與專注在資產或攻擊者的分析方式不同，威脅建模工具注重在軟體開發本身，以建立資料流程圖(Data Flow Diagrams)活動為例，開發人員對這類軟體開發活動已經相當熟悉，於是可以更容易了解威脅建模的精神。

3.4.1.5.1. 工具下載與安裝

威脅建模工具可在微軟的 SDLC 官方網站進行下載[19]，其相關支援環境需求詳見表 18。

本文件之智慧財產權屬行政院資通安全辦公室所有。

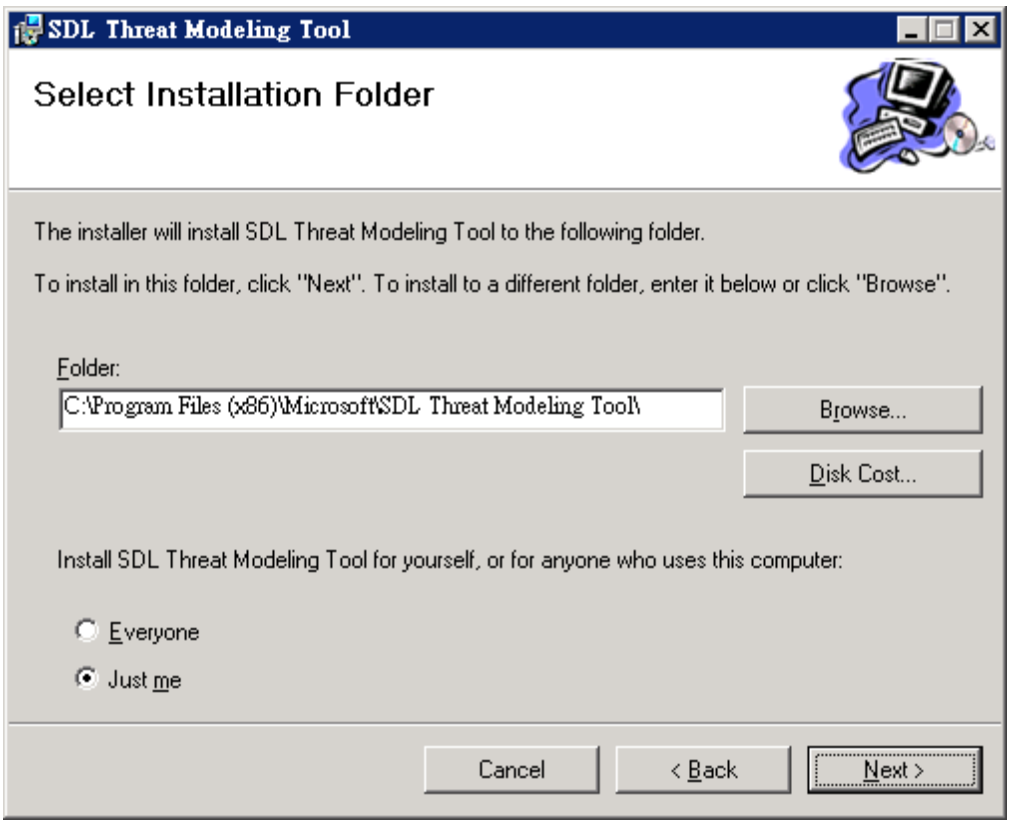
表18 威脅建模工具支援環境

項目	描述
版本	1.0
檔名	MSThreatModelingTool2014.msi
發行日期	2014/4/14
建議使用平台	▪ Windows 7 ▪ Windows 8 ▪ Windows 8.1 ▪ Windows Server 2008 R2 ▪ Windows Server 2012
相依軟體	Microsoft Office Visio

資料來源：本指引整理

下載完成後，與一般的 Windows 安裝軟體相同雙擊兩下即可進行安裝，使用者依需求進行安裝的相關操作即可完成安裝，威脅建模工具安裝畫面詳見圖 16。

本文件之智慧財產權屬行政院資通安全辦公室所有。



資料來源：本指引整理

圖16 威脅建模安裝畫面

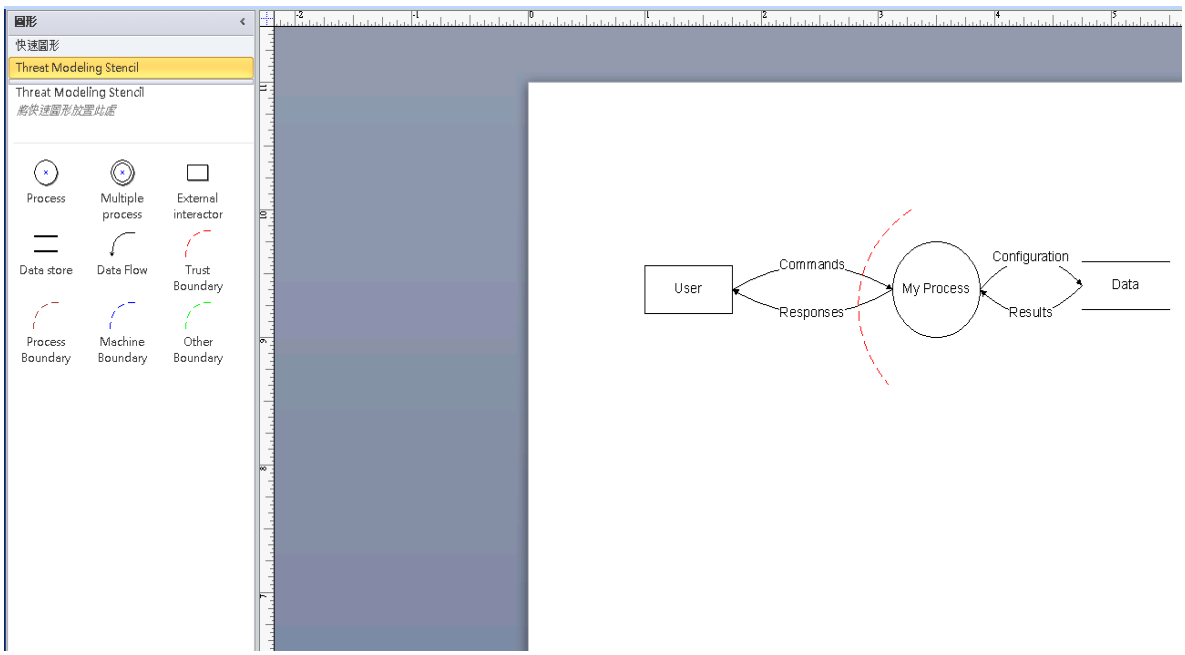
3.4.1.5.2. 威脅建模工具使用介紹

威脅建模工具是建立在微軟提出的威脅建模方法論上使用的，其使用步驟分為建立資料流圖形、進行 STRIDE 分析、建立環境剖繪及產生威脅建模報告 4 個主要步驟。

●建立資料流圖形

建立資料流圖形為威脅建模的第一個步驟，透過將系統分解為「外部實體」、「資料流」、「資料儲存庫」及「程序」等 4 類元件，清楚描述系統中可能的資料流，此部分在本章已有充分介紹，此節不再另行贅述，建立資料流圖形功能畫面，詳見圖 17。

本文件之智慧財產權屬行政院資通安全辦公室所有。



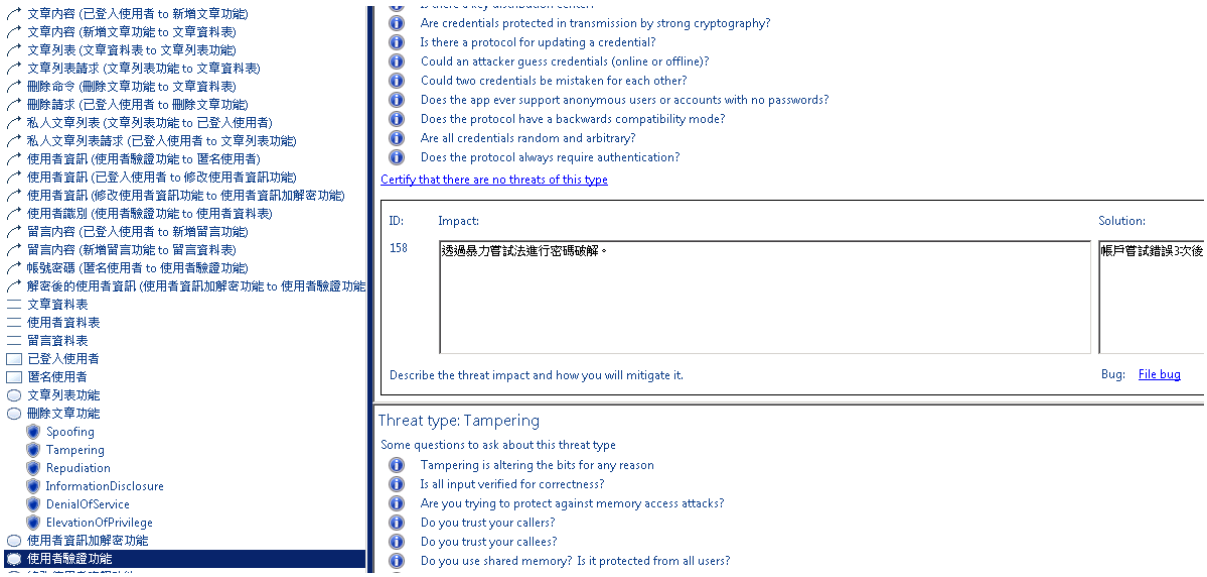
資料來源：本指引整理

圖17 建立資料流圖形

●STRIDE 分析

威脅建模第二步驟為 STRIDE 分析，透過此方式識別資料流圖形中可能產生的威脅進而提出防範措施，威脅建模工具提供自動化的方式將資料流圖形中個各元件產生對應的 STRIDE 分析介面，提供開發人員填入對應的威脅分析與控制措施，STRIDE 分析介面，詳見圖 18。

本文件之智慧財產權屬行政院資通安全辦公室所有。



資料來源：本指引整理

圖18 STRIDE 分析介面

開發人員可依據威脅建模工具自動化產生的欄位進行 STRIDE 分析，倘若針對整個元素分析結果發現並不構成風險，開發人員亦可透過選項的方式，勾選不具風險的顯像並填入不具風險的說明，詳見圖 19。



資料來源：本指引整理

圖19 排除風險選項

本文件之智慧財產權屬行政院資通安全辦公室所有。

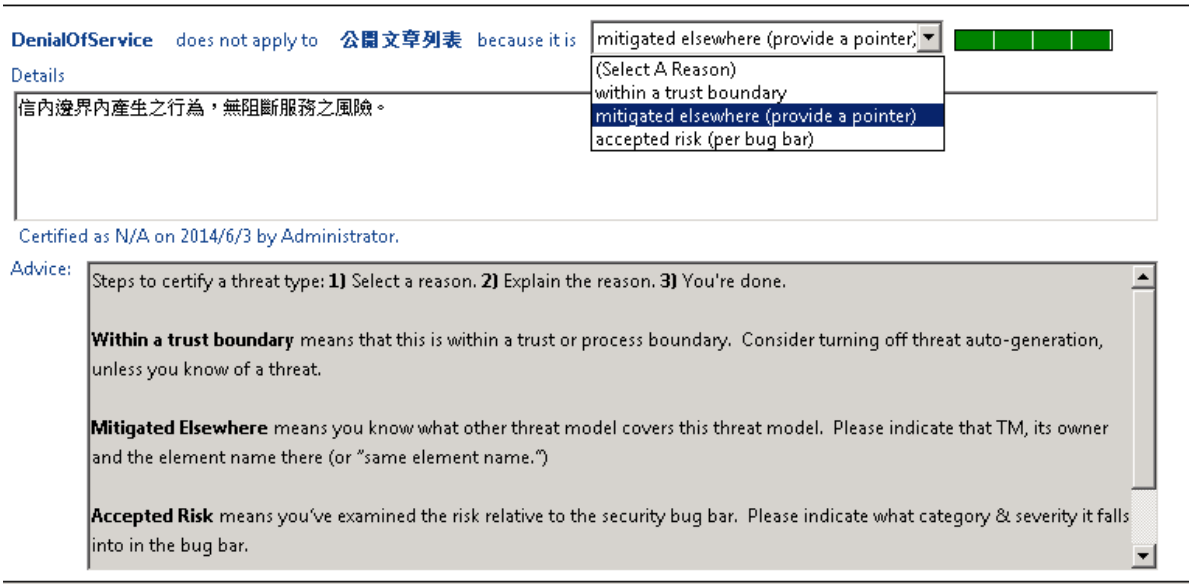
另一種可能的狀況是分析某元素時具有部分的風險可以排除，則開發人員亦可透過選項並加入說明的方式排除特定風險，威脅建模工具提供下列 3 種選項進行風險排除：

– 屬於信任邊界內。

– 以在其他地方進行防護(指出位置)。

– 接受風險。

排除特定風險介面，詳見圖 20。



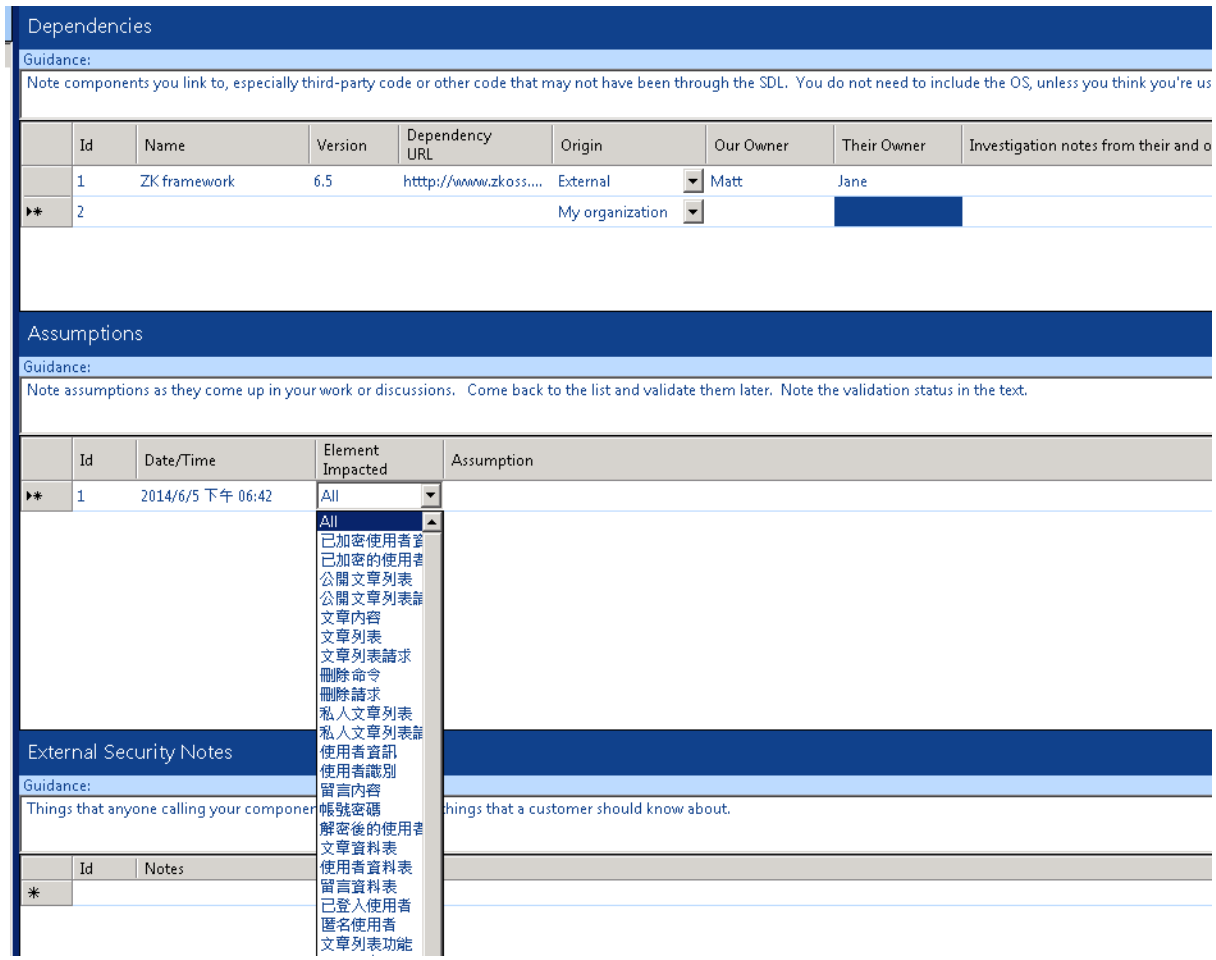
資料來源：本指引整理

圖20 排除特定風險選項

●建立環境剖繪

威脅建模工具同時提供建立環境剖繪的功能，與專注於軟體本身的威脅分析不同，其內容包含第三方的元件分析、開發人員討論設計過程中產生的問題及軟體使用者或顧客所須知的安全註記。此功能目的在於彌補威脅建模中非軟體開發本身的問題，詳見圖 21。

本文件之智慧財產權屬行政院資通安全辦公室所有。



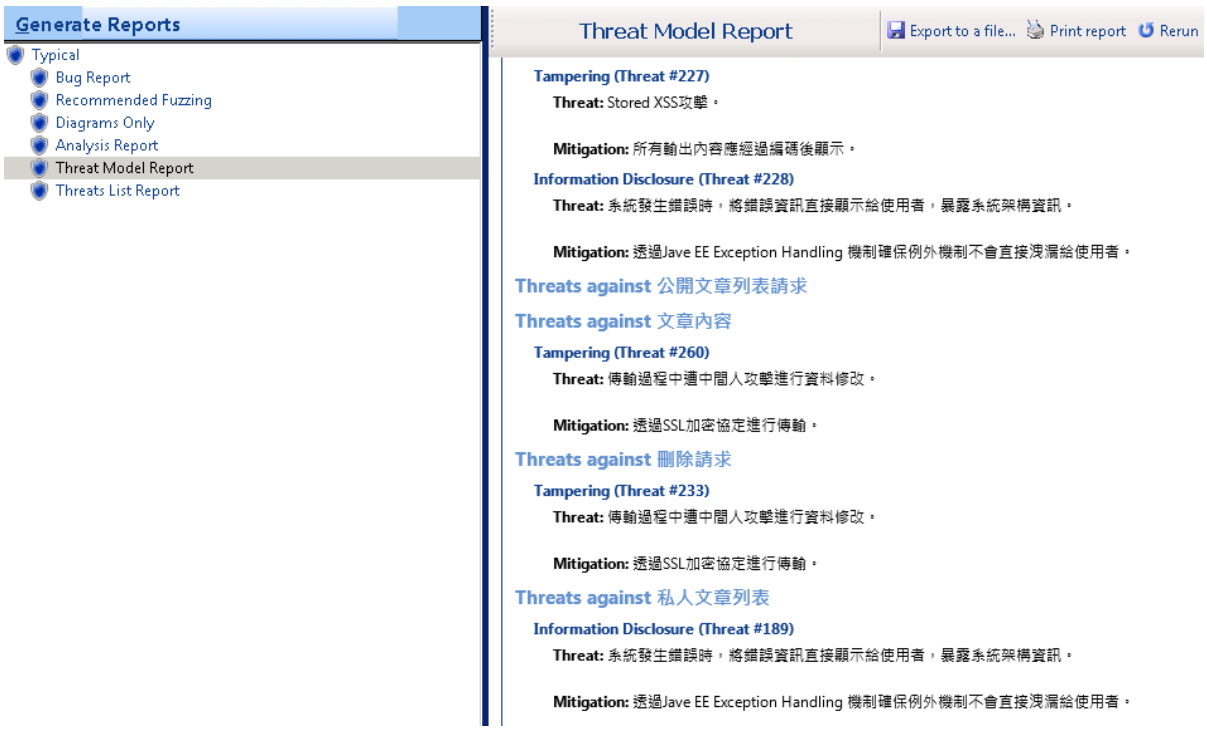
資料來源：本指引整理

圖21 建立環境剖繪

●產生威脅建模報告

顧名思義此步驟為威脅建模最後步驟，威脅建模工具透過前三項步驟作為輸入，輸出一份威脅建模報告。開發人員可以依據威脅建模報告所產生的結果進行後續安全開發使用，詳見圖 22。

本文件之智慧財產權屬行政院資通安全辦公室所有。



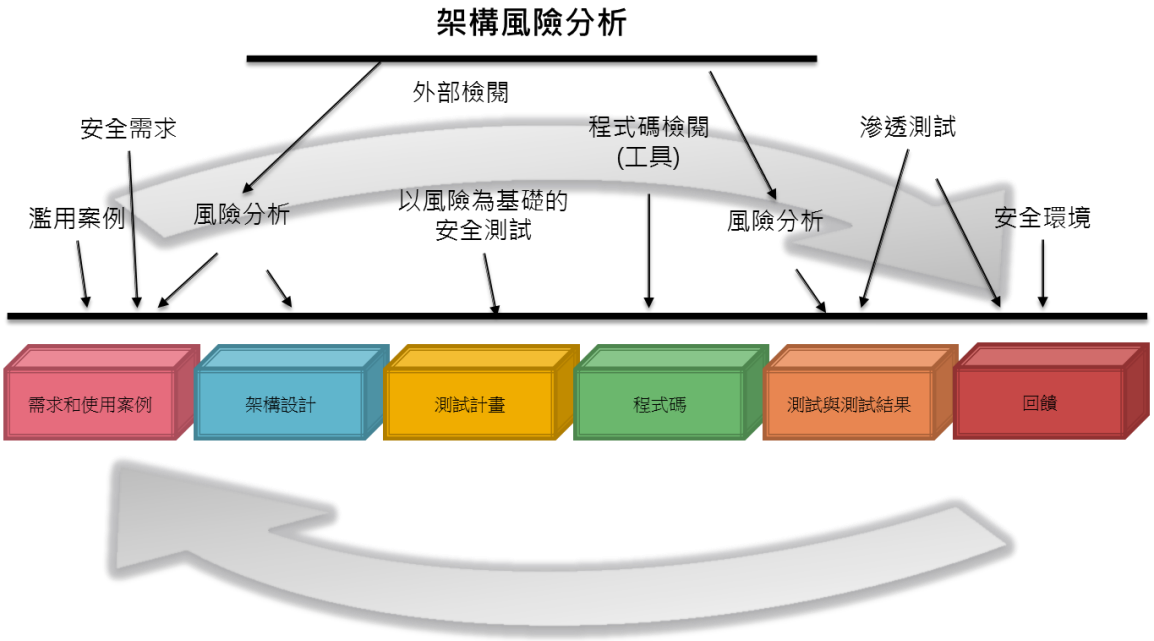
資料來源：本指引整理

圖22 產生威脅建模報告

3.4.2. 架構風險分析(Architecture Risk Analysis, ARA)[20]

架構風險分析(ARA)是另一種用來進行風險分析的方式，同樣也是透過威脅評估，考慮其優先順序後建構一個系統信任和威脅的模型，並且進一步分析進而規劃安全控制措施。

本文件之智慧財產權屬行政院資通安全辦公室所有。



資料來源：本指引整理

圖23 架構風險分析示意圖

當檢視系統設計時，其中一個考慮的因素就是確保系統是否滿足相關的安全目標，以下簡介兩種主流之模型。

●CIA

CIA 為機密性(Confidentiality)、完整性(Integrity)和可用性(Availability)，以一個比較高層級的方式去定義安全目標。

– 機密性

限制正確使用者的資訊存取和洩露；防止錯誤使用者透過存取或洩露的方式取得資訊。

– 完整性

資訊資料的可信度。

– 可用性

本文件之智慧財產權屬行政院資通安全辦公室所有。

資訊系統提供存取的權限給被授權的使用者。

●Viega and McGraw

Viega and McGraw[20]提出了更詳細的列表來代替 CIA 所定義的安全目標，更精細的分類可以讓軟體生命發展週期中的安全目標更容易去操作及測量。以下是 Viega and McGraw 所提出的列表：

– 預防。

– 可追溯性和審核。

– 監控。

– 隱私和保密性。

– 多重安全性。

– 匿名。

– 授權。

– 完整性。

而軟體安全問題非常複雜，在這裡把安全漏洞分為二類，執行時期發生的錯誤及軟體架構上的缺陷。

而架構風險分析主要可以分為現存架構弱點分析(Underlying Framework Weakness Analysis)，抗攻擊能力分析(Attack Resistance Analysis)與模糊分析(Ambiguity Analysis)此 3 大子流程(詳見圖 24)，以下針對此 3 流程進行介紹。

本文件之智慧財產權屬行政院資通安全辦公室所有。



資料來源：本指引整理

圖24 架構風險分析子流程

3.4.2.1. 抗攻擊能力分析

透過套用已知的攻擊列表，提供檢視目前系統設計上還存在之資安攻擊威脅，如微軟的 STRIDE 模型或 MITRE 的常見缺失列舉計畫，可以套用已知攻擊檢核表，藉由套用常見之已知攻擊檢核表，提供開發者提早預防可能存在之攻擊，而常見的弱點分類包含[20]：

●McGraw 提出的 7 Kingdoms of Vulnerability。

●19 Deadly Sins ; Howard, LeBlanc, Viega。

●Sans Top 25。

●WASC 24。

●OWASP Top 10。

本文件之智慧財產權屬行政院資通安全辦公室所有。

●CWE(Common Weakness Enumeration)

抗攻擊能力分析適合用來找出目前軟體或系統中，是否具有已知的弱點，較不適用於找出未知的問題。

抗攻擊能力分析通常可找出以下領域的安全問題：

●不安全的令牌產生與管理。

●不正確的密碼學應用。

●容易被顛覆的安全防護元件。

●信任或權限問題。

而針對企業應用程式的設計元素而言，有以下幾點是需要注意的：

●企業應用程式的通用設計元件。

●企業設計元素：分散式架構。

●企業設計元素：動態程式碼產生和解讀。

●企業設計元素：透過無狀態協議存取 API。

●企業設計元素：豐富的網路應用程式。

●JavaScript 劫持攻擊。

●插入 AJAX。

●企業設計元素：服務導向架構(SOA)。

3.4.2.2. 模糊分析

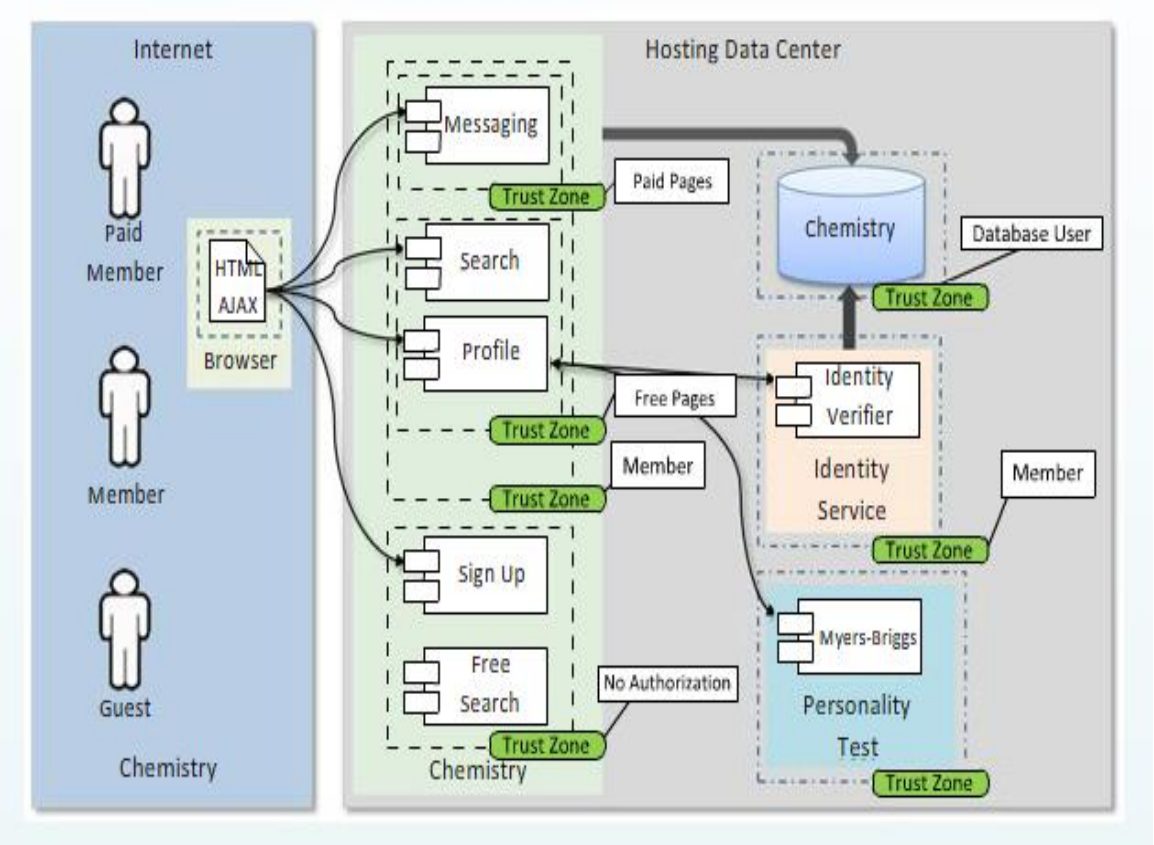
模糊分析是用來發現新威脅的分析活動。這個分析需要對於軟體本身具有相當程度了解的兩位(或以上)人員。將人員分成兩個團隊分開進行相同的安

本文件之智慧財產權屬行政院資通安全辦公室所有。

全相關分析活動，然後在兩個團隊分別完成後，合併兩個團隊進行分析結果的差異分析。這樣的活動可幫助找出軟體或系統中模糊的、不一致的地方，或說是兩個團隊認知不同的安全機制作法或設計，而這些不清楚、不一致的地方正是需要進一步分析，可能找出問題之處。我們可使用各種建模的技術來幫助分析應用系統中潛在的漏洞風險，這裡提到 3 種常見的建模技術：信任建模、資料機敏性建模以及威脅建模。描述如下：

●信任建模

信任建模其實就是在識別出資料和功能在安全政策中設定的邊界。在設計階段時以服務為基礎定義出信任的邊界，詳見圖 25。

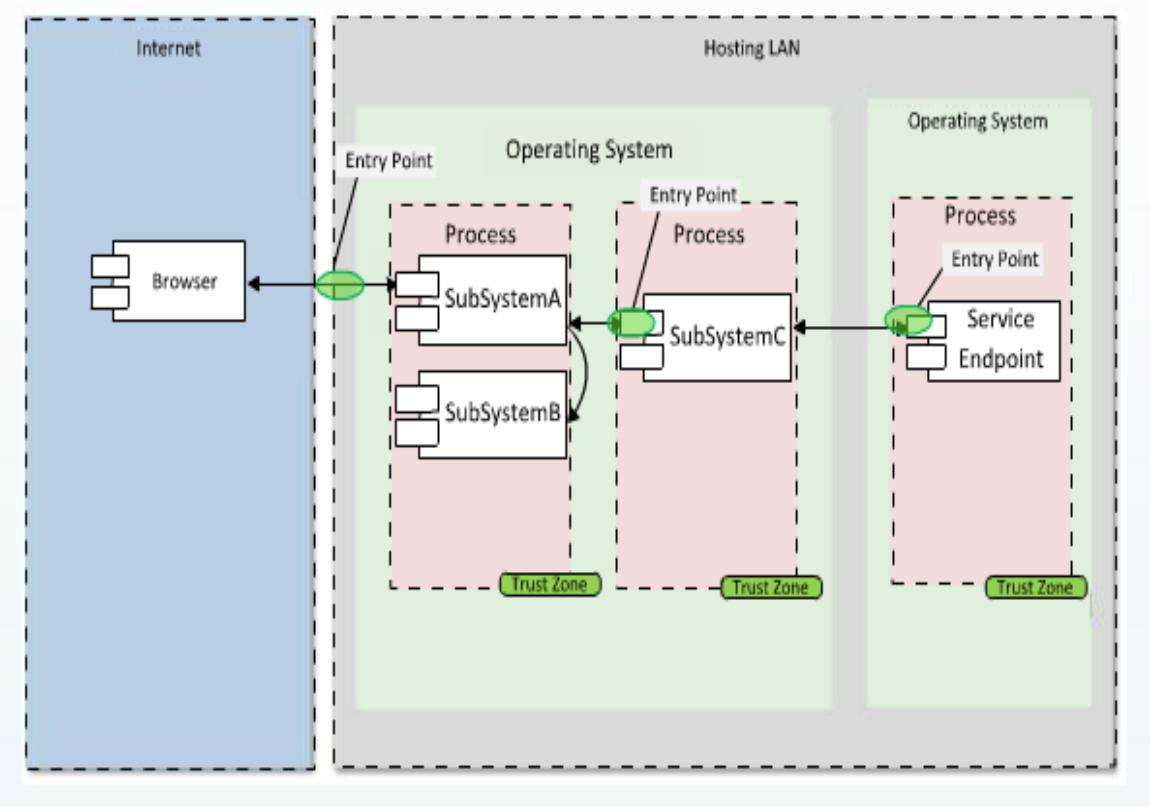


資料來源：[20]

圖25 信任建模步驟 1

本文件之智慧財產權屬行政院資通安全辦公室所有。

當跨越信任邊界的控制流被調用時，就必須再次建立信任層級。而且每一層應用程式都從一套信任區域規範而開始，詳見圖 26。

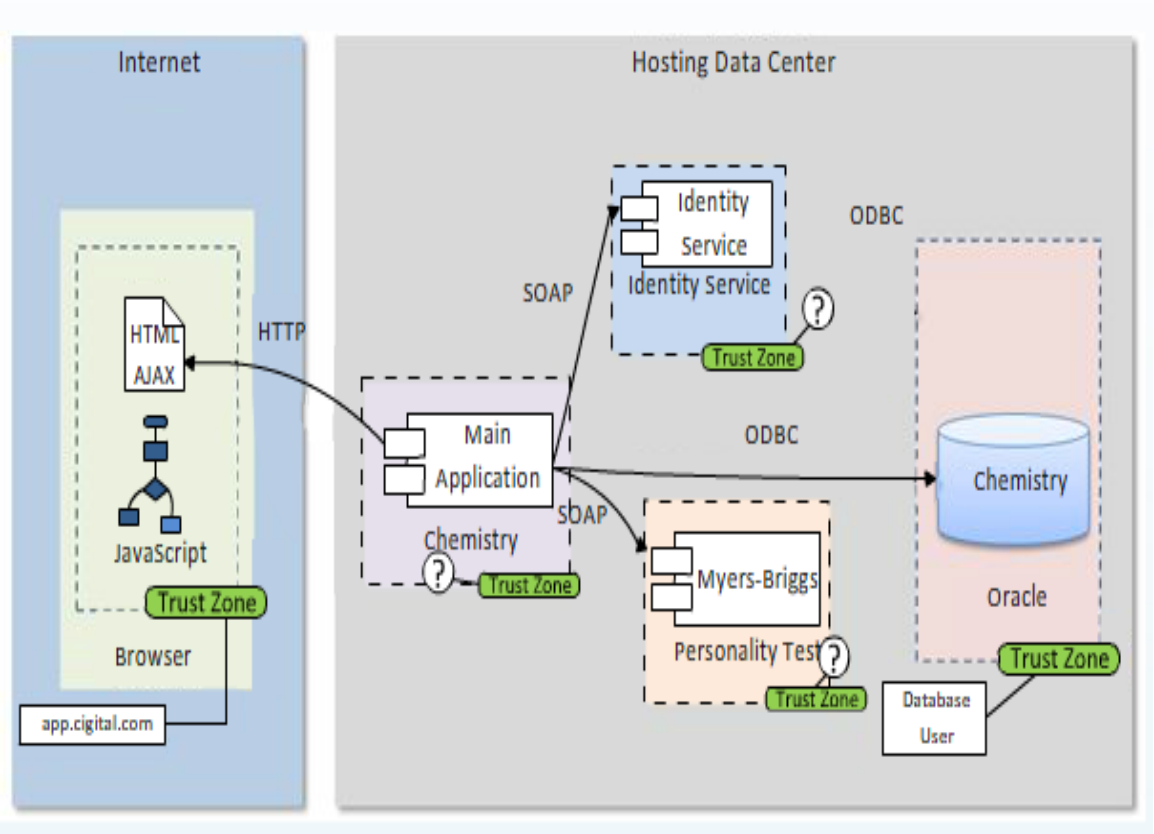


資料來源：[20]

圖26 信任建模步驟 2

服務會額外增加應用程式信任建模的複雜度，詳見圖 27。

本文件之智慧財產權屬行政院資通安全辦公室所有。



資料來源：[20]

圖27 信任建模步驟 3

●資料機敏性建模

資料機敏性建模其實就是要識別出資料在應用程式的隱私和信任問題。資訊可以分類為系統配置資料以及應用程式資料，而系統配置資料又可以進一步分類為安全性及非安全性資料；應用程式資料又分為個人或普通資料以及特有和機密資料。所以必須根據資料內容區分出各種資料的類型，進而建立信任區域保護所識別出的機敏資料。

●威脅建模

威脅建模就是識別出需要保護的功能和資料、攻擊者以及那些攻擊者可以利用的漏洞。可以透過以下幾點來識別出威脅及針對威脅進行分析：

本文件之智慧財產權屬行政院資通安全辦公室所有。

– 能力

➢存取系統。

➢實施逆向工程。

➢監聽網路封包。

– 動機

➢個人因素。

➢挑戰。

➢競爭力。

– 技巧層級

➢有經驗的駭客。

➢使用現成駭客軟體的駭客。

➢內部人員。

– 資源和相關工具

➢簡單的手動執行。

➢分散式殭屍網路。

➢資金雄厚的組織。

➢存取內部資訊。

威脅建模其中一個重要步驟就是識別出資產，通常是應用程式的功能、機敏資訊、用來控制應用程式狀態的資料等。

3.4.2.3. 弱點分析

本文件之智慧財產權屬行政院資通安全辦公室所有。

現存架構弱點分析中，由於軟體不是僅由程式設計師自行撰寫的程式碼構成的。現代的軟體通常建立在複雜的軟體框架(Framework)之上，並且引用眾多的外部函式庫。有些軟體依賴中間軟體(Middleware)進行管理或提供服務(例如 Web 應用程式需透過 Web 伺服器軟體提供服務)。所以須將系統使用之架構與工具之相依性進行彙整，進行現存架構之風險分析，檢視架構本身的安全性與套用架構之後對於安全性的影響。

欲找出軟體依賴所產生的安全問題，需要考量軟體的以下依賴項目(詳見圖 28 所示)：

●函式庫及其版本。

●外購套裝或客製軟體，包含提供安全特性的套裝軟體。

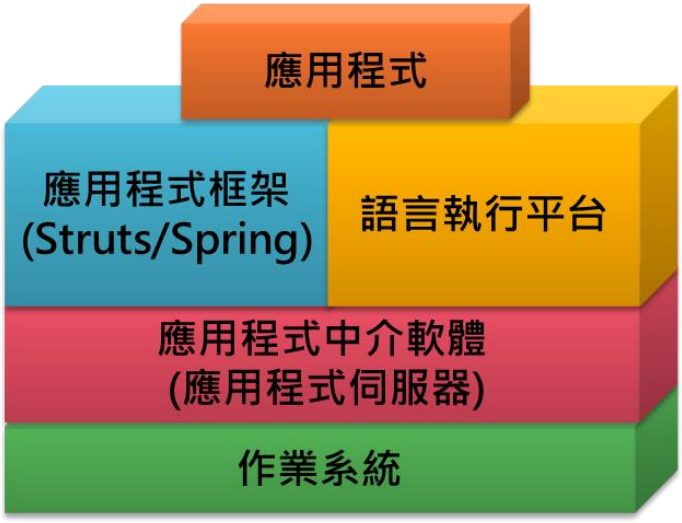
●軟體框架(例如.NET、JavaEE 等)。

●軟體執行的平台或環境。

●實體環境、裝置。

●建置環境。

本文件之智慧財產權屬行政院資通安全辦公室所有。



資料來源：本指引整理

圖28 軟體架構

考量的方向包含：

●依賴項目本身是否具有已知弱點。

●依賴項目的安全性是否透過某些設定或必須關閉某些特性。

●依賴項目的安全控制措施是否足夠。

而應用程式環境也提供了一些基本的控制措施。詳見表 19。

表19 控制措施

安全需求	控制措施
密碼學	JCA
身分驗證與授權	JAAS
輸入驗證和輸出編碼	.Net 的 validateRequest
沙箱	JavaScript 的同源策略

資料來源：本指引整理

本文件之智慧財產權屬行政院資通安全辦公室所有。

3.5.控制措施

在設計階段中透過 MS-Style Threat Modeling 以及架構風險分析，評估整體系統風險，並且經過風險排序之後，接下來就要針對這些風險來訂定相關的控制措施，一般來講，控制措施可依照需求類型的不同分為 14 類[21]：

●安全架構文件需求

必須針對所有應用程式所使用到的元件，包含商業或安全函式相關元件，即使它們不屬於應用程式的一部分。

●身分認證需求

除了公開資訊外，所有資訊取得都必須通過驗證，而且所有認證資訊都必須經過加密存放，認證的行為必須被記錄下來。

●會談管理

應用程式所使用到的相關 Session 都必須經過管理，而且要設定有效時間及通過認證。

●存取控制驗證需求

確認使用者在未通過認證前是不能進行存取任何需要認證的相關動作，而且只能存取權限內的服務及所有動作都必須被記錄。

●輸入確認驗證需求

確保所有輸入都必須經過驗證而且輸入錯誤都必須被記錄下來。

●輸出編碼/跳脫驗證需求

確認所有輸出都有經過編碼/跳脫，而且都必須由伺服器端進行相當控制措施。

本文件之智慧財產權屬行政院資通安全辦公室所有。

●加解密驗證需求

確保所有機敏資料都需要加密，而且要建立完善的加解密機制。

●錯誤處理與紀錄驗證需求

所有事件發生都必須被完整記錄下來且不可包含任何機敏資訊在內。

●資料保護驗證需求

所有傳送到用戶端機敏資料的快取或暫存都必須受到保護，而且資料一定要放在 HTTP 訊息本文內才可傳送並規定明確的保護政策。

●通訊安全驗證需求

所有和機敏資料或功能有關的對外連線都比較經過驗證而且設為最小權限。

●HTTP 安全驗證需求

所有導向指令都不可以包含未經驗證的資料，而且只能接收事先定義好的 HTTP 要求指令。

●安全設定驗證需求

所有機敏資訊都必須存在受保護的地方，避免未授權的存取，而且所有存取行為都必須依照安全設定。

●惡意代碼檢查需求

原始碼在任何時候都不能包含惡意代碼。

●內部安全需求驗證

禁止所有未授權的存取動作。

本文件之智慧財產權屬行政院資通安全辦公室所有。

可以透過一些已經普遍被大眾所採用的一些技術套用在以上這些安全類別中，以確保在進行應用程式安全檢核時有符合要求。詳見表 20 範例，但實際上要採用那些控制措施，還需視各應用程式所需的安全需求去客製化。

表20 安全要求與控制措施範例

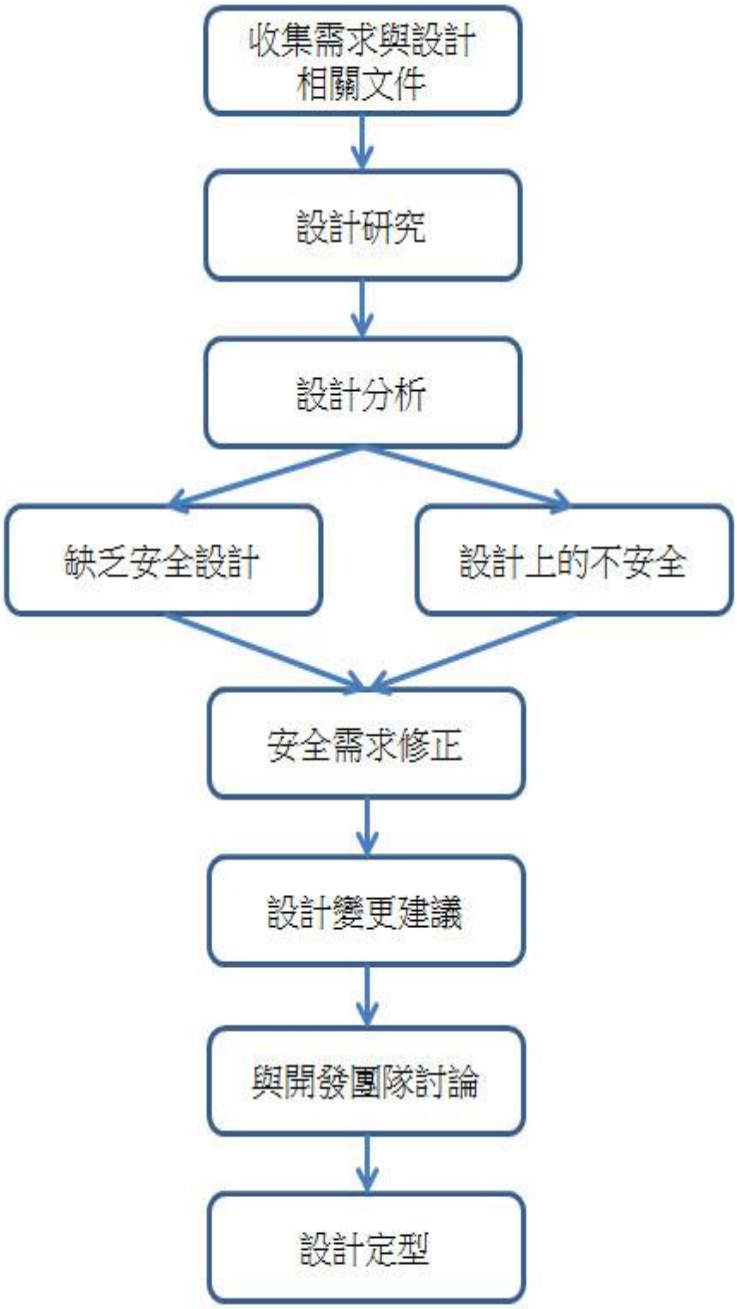
安全要求	控制措施
身分認證需求	JAAS
通訊安全驗證需求	TLS V1.2
輸入確認驗證需求	.Net 的 validateRequest
惡意代碼檢查需求	Fortify 源碼檢測
加解密驗證需求	Hash 函式 RSA AES

資料來源：本指引整理

3.6.安全設計審查(Secure Design Review)

進行一連安全軟體設計的實務活動之後，為確保安全設計能符合需求階段提出的相關安全需求及安全設計是否能滿足軟體安全的基準線，因此在設計階段結束前安全設計審查是必要的，安全設計審查流程，詳見圖 29。

本文件之智慧財產權屬行政院資通安全辦公室所有。



資料來源：[22]

圖29 安全設計審查流程

流程主要階段分別為收集設計文件、研究系統設計、設計分析、修正安全需求、設計變更建議、與開發團隊討論及設計定型 7 個階段。

本文件之智慧財產權屬行政院資通安全辦公室所有。

3.6.1. 收集需求與設計相關文件

取得需求階段產生出的所有安全需求，例如來自「需求追溯矩陣」中的安全需求。另外必須收集開發團隊於設計階段產出的所有種類的設計文件，可能包含使用案例圖、活動圖、類別圖等。

3.6.2. 研究設計

研究系統設計是透過研讀系統文件後，完整地了解資系統資料流、系統中元件的屬性與如何交互作用、系統資料處理的方式等。這些都必須透過手動的分析並與設計或架構團隊進行討論來達成，整個系統的設計與架構必須在此時完整的了解，才有辦法辨別出可能產生資安裂縫的弱點區域，系統設計若有下列功能一定要被視為關鍵區域檢視，包含：

- 資料流。
- 存取控制。
- 現存/框架內建的安全控制措施。
- 與外部服務的整合。
- 資料來源與設定檔案的位置。
- 附加元件。

這些有助於鑑別系統的信任邊界並幫助判斷弱點及風險層級。

3.6.3. 設計分析

了解設計後下一個步驟就是分析設計中潛在的威脅。主要有兩個方向：

- 缺乏安全設計

  審查所有清單上的安全需求，是否都有對應的安全設計、安全架構文件。

本文件之智慧財產權屬行政院資通安全辦公室所有。

針對每個安全要求進行闡述圖形，展示設計層級的作法。其主要目標就是確認所有目前已知的安全需求都有被安全設計所解決。任何安全需求沒有明確在設計文件中呈現的，都應該被當作分析的發現。

●設計上的不安全

識別軟體設計中的「安全特點(Security Feature)」(例如，身分認證、存取控制、使用加密等)，然後檢視這些安全特點是否存在問題使得安全性不足或是完全失效，關於軟體設計中可能發生的不安全設計，詳見表 21。

表21 軟體安全特點不安全設計範例

類型	不安全設計
機密性	▪採用 SSL 加密卻未停用 SSLv2、v3 等相關具有弱點的行定 ▪採用具有弱點的 OpenSSL 版本進行線上服務
完整性	▪使用頁面隱藏欄位作為網站資料傳輸方式 ▪將輸入驗證實作在客戶端執行的 Javascript 進行檢查
可用性	▪採用不具可靠度的傳輸協定，如 UDP ▪未對資料進行完整性驗證即匯入
身分認證	▪自行開發不嚴密的會談管理機制 ▪透過明文傳輸使用者識別資訊
授權	▪透過隱藏欄位進行權限管控
稽核	▪於 Log 紀錄內紀錄敏感資訊 ▪將使用者輸入作為 Log 內容來源
會話管理	▪錯誤的會談逾期時間設定
錯誤及例外管理	▪使用系統預設的例外處理機制
組態管理	▪使用預設組態設定

本文件之智慧財產權屬行政院資通安全辦公室所有。

類型	不安全設計

資料來源：本指引整理

3.6.4. 修正安全需求

分析設計中不安全的部分與缺乏的安全設計後，相對應的安全需求列表應該被建立並被回饋到「需求追溯矩陣」中。找出的安全需求是高階的、與設計整合的需求，例如，「先行驗證從網頁欄位中輸入的資料然後才進行相關處理」。

3.6.5. 建議設計變更

在此步驟中，所有透過前述步驟找到的安全需求，應關連到相對應的控制措施，並且提出對目前設計的變更建議。設計的變更建議應採用明確方式進行說明，以「針對輸入驗證的變更建議」舉例如下：

- 識別軟體中正確的元件。
- 安置檢查點。
- 實作驗證機制。
- 驗證機制採用第三方 API 或者採用軟體框架本身的功能。

3.6.6. 與開發團隊討論

與開發團隊討論設計變更建議項目，開發團隊對變更建議的疑問必須加以處理，並確保變更建議的可行性。如果有的話，必須考慮例外情況，以提出替代方案或修正原先的建議作法。在此步驟最後，將達成並產生一致同意的控制措施作法。

3.6.7. 設計定型

本文件之智慧財產權屬行政院資通安全辦公室所有。

由開發團隊將設計變更建議項目納入最終設計規格後，必須重新審查並確定進一步開發的程序。

本文件之智慧財產權屬行政院資通安全辦公室所有。

4. 案例分析

本章會透過案例方式示範安全的軟體設計過程，本指引選擇微軟的 SDL 方法來進行示範，其範圍包含從需求規格進行威脅建模、套用 STRIDE 的方式進行威脅分析，將分析結果透過 DREAD 評鑑標準公式進行威脅排序，最後產出安全需求後填入需求追朔矩陣，以利後續實作及測試使用。

示範的過程當中，我們使用了微軟 SDL 官方網站所提供的 Microsoft Threat Modeling Tool 2014[19] (以下簡稱威脅建模工具)，其安裝與使用方法請參照 3.4.1.5 工具介紹。

4.1.案例一 Web 應用程式

4.1.1. 案例介紹

本指引的使用案例為透過 Java EE 開發的網頁部落格，此部落格提供使用者註冊後即可發表部落格文章功能，使用者在註冊時要設定自己的帳號密碼意外還要填入一些個人資本資訊，也因如此該部落格會蒐集保存個人資訊等高敏感資料，因此為滿足安全性需求，該部落格有採購防火牆設備以及硬體加密模組並預計整合於系統當中。

如同一般的部落格所提供的功能，該系統的使用角色分為匿名使用者與登入後的使用者，登入後的使用者可以進行文章發表、留言與刪除，此外已登入使用者可以編輯自己的使用者個人資訊，匿名使用者可以讀取部落格上的文章及留言，其詳細的系統功能詳見表 22。

表22 網頁部落格功能列表

功能編號	功能描述
B-A-01	任何人皆可取讀取部落格公開文章

本文件之智慧財產權屬行政院資通安全辦公室所有。

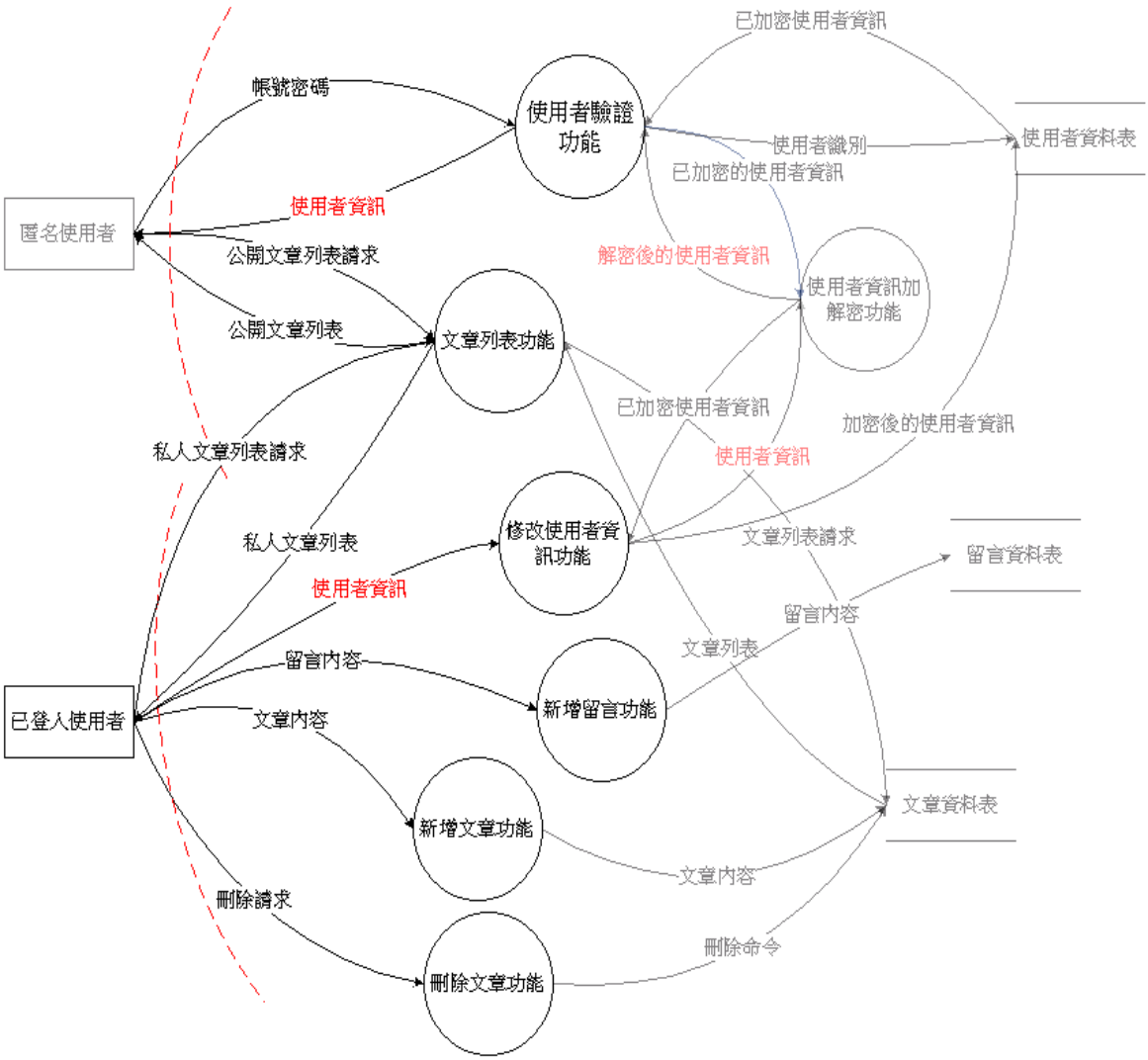
功能編號	功能描述
B-A-02	已登入使用者可以發表文章
B-A-03	已登入使用者可以刪除文章
B-M-01	已登入使用者可對公開文章進行留言
B-U-01	匿名使用者可以透過登入動作成為已登入使用者
B-U-02	已登入使用者可以修改個人使用者資料
B-U-03	所有使用者個人資訊應受到加密保護

資料來源：本指引整理

4.1.2. 建立資料流程圖

在取得系統的相關文件與功能需求後，即可透過威脅建模的方式進行安全軟體設計的方法，而建立資料流程圖(Data Flow Diagrams, DFD)則是威脅建模的第一步，建立資料流程圖是透過辨別出系統的外實體、程序、資料流、資料儲存庫以及信任邊界的方式，對系統資料流架構做出一個完整的描述以利分析，本案例中依據網頁部落格功能列表所描述的功能進行資料流程圖繪製，詳見圖 30。

本文件之智慧財產權屬行政院資通安全辦公室所有。



資料來源：本指引整理

圖30 網頁部落格資料流程圖

從上圖可以看到整個系統的資料流程圖中分為 2 個外部實體，7 個程序以及 3 個資料儲存庫，並透過信任邊界將外部實體與系統架構隔離以呈現出整個系統資料流程圖。其中圖中部分元件為灰色標示，此乃威脅建模工具依據開發人員威脅評估結果，自動將無威脅的部分以灰色顯示，此外為強調敏感資料流的標示，本指引同時將重要的敏感資料流以紅色的字體呈現，讓架構圖可以更清楚呈現。

本文件之智慧財產權屬行政院資通安全辦公室所有。

4.1.3. 套用 STRIDE 分析模型

完成資料流程圖後，威脅建模工具會依照流程圖中每個不同屬性的元件自動產生 STRIDE 分析列表，威脅建模工具產生 STRIDE 列表，詳見圖 31。

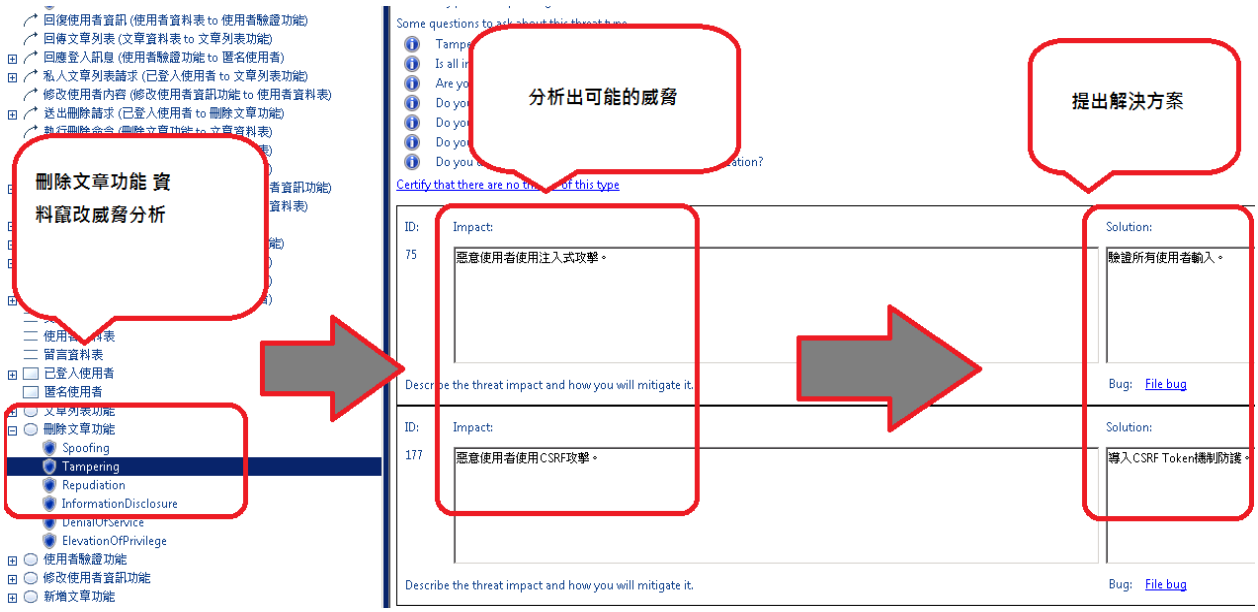


資料來源：本指引整理

圖31 網頁部落格分析模型列表

此時威脅建模必須依據列表中的每個項目進行風險評估，依據實際狀況將風險排除或列舉可能風險並填入相對應的控制措施，以刪除文章功能為例，此功能在系統資料流程圖中屬於「程序(Process)」，按照微軟威脅建模方法程序可能遭遇到 STRIDE 中 6 種所有可能的風險，此時便要分別的為這 6 種可能的風險類型進行分析，填入可能的威脅及其對應的解決之道，以此程序可能遭遇到的竄改風險為例，本指引分析出具有「惡意使用者使用注入式攻擊」及「惡意使用者進行 CSRF 攻擊」2 項威脅，因此提出了「驗證所有使用者輸入」以及「導入 CSRF Token 機制」2 項對應的控制措施進行防範，其範例詳見圖 32。

本文件之智慧財產權屬行政院資通安全辦公室所有。



資料來源：本指引整理

圖32 網頁部落格刪除文章竄改分析

依照上述方法將資料流程圖所有元素進行分析後，本指引整理出威脅與控制措施對應表並以威脅(Threat)的 T 作為代號進行標示，詳見表 23。

表23 網頁部落格威脅與控制措施對應表

編號	威脅	控制措施
T-1	系統發生錯誤時，將錯誤訊息顯示給使用者，暴露系統架構資訊	透過 Java EE Exception Handling 機制，確保系統錯誤訊息不洩漏給使用者
T-2	因中間人攻擊導致身分遭冒用或資訊被竄改	使用 SSL 加密協定進行傳輸
T-3	使用者識別遭偽造或未登入可進行需登入之操作	使用 Java EE Session Management 功能進行使用者識別

本文件之智慧財產權屬行政院資通安全辦公室所有。

編號	威脅	控制措施
T-4	使用者否認自己的操作行為	所有操作應經過 Log 機制進行紀錄保存
T-5	惡意使用者進行 Stored XSS 攻擊	所有輸出內容應經編碼後顯示
T-6	使用者透過網址修改進行非其權限資料操作	導入使用者權限控機制
T-7	使用者遭受 CSRF 攻擊	導入 CSRF Token 機制
T-8	惡意使用者使用注入式攻擊	驗證所有使用者輸入
T-9	惡意使用者透過暴力法進行密碼破解	帳戶於 30 分鐘內登入錯誤達 3 次後鎖定
T-10	使用者帳戶遭駭，洩漏使用者各資	所有使用者個資皆透過遮罩處理
T-11	傳輸過程遭竊聽	使用 SSL 加密協定進行傳輸
T-12	送出大量請求，導致服務中斷	導入 CAPTCHA 機制防止自動化攻擊

資料來源：本指引整理

此外 STRIDE 分析過程中，有些風險發生的可能性很低或已有其他控制措施進行防護時，可以視為可接受之風險。在威脅建模工具中又分為「信任邊界內之行為」、「已有其他防護措施」以及「接受風險」3 種分類，本指引整理出網頁部落格風險接受的列表並以威脅(Acceptance)的 A 作為代號進行標示，詳見表 24。

本文件之智慧財產權屬行政院資通安全辦公室所有。

表24 網頁部落格風險接受表

編號	接受風險類型	接受風險描述
A-1	信任邊界內之行為	此為信任邊界內的行為，風險發生可能性極低
A-2	已有其他防護措施	透過防火牆功能阻擋阻斷式服務攻擊
A-3	接受風險	為公開資源或服務，無偽冒風險
A-4	接受風險	為單純請求，竄改行為無法對整體資料流有任何改狀態改變
A-5	接受風險	進行公開資源或服務的操作，無否認行為風險
A-6	接受風險	進行公開資源或服務的操作，無資訊洩漏風險

資料來源：本指引整理

此階段所產出的「威脅與控制措施對應表」與「風險接受表」為透過威脅建模工具協助進行 STRIDE 分析後整理而出。威脅建模工具中整理出的威脅與控制措施會以條列文字方式呈現，但為求案例分析的詳細與透徹，本指引自行整理其 STRIDE 對應表，並依微軟威脅建模方法分為「資料流」、「資料儲存庫」、「外部實體」及「程序」4 個表格，對照「風險接受表」與「威脅與控制措施對應表」可更清楚地了解微軟威脅建模之精神。

本文件之智慧財產權屬行政院資通安全辦公室所有。

●資料流 TID 分析

微軟威脅建模方法中資料流可能具有竄改(T)、資訊洩漏(I)及拒絕存取服務(D)等 3 種可能風險，其中資料流又分為信任邊界內資料流以及跨信任邊界資料流，依其類型之不同應考量的威脅角度也不同，網頁部落格資料流 STRIDE 分析結果詳見表 25。

表25 網頁部落格資料流 TID 分析表

	S	T	R	I	D	E
可能威脅：竄改、資訊洩漏及拒絕存取服務 ◎：跨信任邊界						
已加密使用者資訊(修改使用者資訊功能對使用者資料表)		A-1		A-1	A-1	
已加密使用者資訊(加解密功能對修改使用者資訊功能)		A-1		A-1	A-1	
已加密使用者資訊(使用者資料表對使用者驗證功能)		A-1		A-1	A-1	
已加密使用者資訊(使用者驗證功能對加解密功能)		A-1		A-1	A-1	
◎公開文章列表(文章列表功能對匿名使用者)		A-3		T-1	A-1	
◎公開文章列表請求(匿名使用者對文章列表功能)		A-4		A-6	A-2	
◎文章內容(已登入使用者對新增文章功能)		T-2		A-6	A-2	

本文件之智慧財產權屬行政院資通安全辦公室所有。

	S	T	R	I	D	E
文章內容(新增文章功能對文章資料表)		A-1		A-1	A-1	
文章列表(文章資料表對文章列表功能)		A-1		A-1	A-1	
文章列表請求(文章列表功能對文章資料表)		A-1		A-1	A-1	
刪除命令(刪除文章功能對文章資料表)		A-1		A-1	A-1	
◎刪除請求(已登入使用者對刪除文章功能)		T-2		A-6	A-2	
◎私人文章列表(文章列表功能對已登入使用者)		A-1		T-1	A-1	
◎私人文章列表請求(已登入使用者對文章列表請求)		A-4		A-6	A-2	
◎使用者資訊(使用者驗證功能對匿名使用者)		A-1		T-1、T-10	A-1	
◎使用者資訊(已登入使用者對修改使用者資訊功能)		T-2		T-11	A-2	
使用者資訊(修改使用者資訊功能對加解密功能)		A-1		A-1	A-1	
使用者識別(使用者驗證功能對使用者資料表)		A-1		A-1	A-1	

本文件之智慧財產權屬行政院資通安全辦公室所有。

	S	T	R	I	D	E
◎留言內容(已登入使用者對新增留言功能)		T-2		A-6	A-2	
留言內容(新增文章功能對留言資料表)		A-1		A-1	A-1	
◎帳號密碼(匿名使用者對使用者驗證功能)		A-4		T-11	A-2	
已解密的使用者資訊(修改使用者資訊功能對加解密功能)		A-1		A-1	A-1	

資料來源：本指引整理

- 資料儲存庫 TRID 分析

微軟威脅建模方法中資料儲存庫可能具有竄改(T)、否認行為(R)、資訊洩漏(I)及拒絕存取服務(D)等 4 種可能風險，而本案例分析中由於資料儲存庫都屬於信任邊界內之元件較無風險之考量，其 TRID 分析結果，詳見表 26。

表26 網頁部落格資料儲存庫 TRID 分析表

	S	T	R	I	D	E
可能威脅：竄改、否認行為、資訊洩漏及拒絕存取服務						
文章資料表		A-1	A-1	A-1	A-1	

本文件之智慧財產權屬行政院資通安全辦公室所有。

	S	T	R	I	D	E
使用者資料表		A-1	A-1	A-1	A-1	
留言資料表		A-1	A-1	A-1	A-1	

資料來源：本指引整理

●外部實體 SR 分析

微軟威脅建模方法中資料儲存庫可能具有偽冒(S)及否認行為(D)兩種可能風險，其外部實體 SR 分析結果，詳見表 27。

表27 網頁部落格外部實體 SR 分析表

	S	T	R	I	D	E
可能威脅：偽冒及否認行為						
已登入使用者	T-2、T-3		T-4			
匿名使用者	A-3		A-5			

資料來源：本指引整理

本文件之智慧財產權屬行政院資通安全辦公室所有。

●程序 STRIDE 分析

微軟威脅建模方法中程序可能具有偽冒(S)、竄改(T)、否認行為(R)、資訊洩漏(I)、拒絕存取服務(D)及權限提升(E)等 6 種 STRIDE 所有可能風險，詳見表 28。

表28 網頁部落格程序 STRIDE 分析表

	S	T	R	I	D	E
可能威脅：STRIDE 全部						
文章列表功能	T-2	T-5	T-4	T-1	A-2	T-6
刪除文章功能	T-2、T-3、T-7	T-8	T-4	T-1	T-12	T-6
新增文章功能	T-2、T-3、T-7	T-8	T-4	T-1	T-12	T-6
新增留言功能	T-2、T-3、T-7	T-8	T-4	T-1	T-12	T-6
使用者驗證功能	T-9	T-8	T-4	T-1	A-2	T-3
修改使用者資訊功能	T-2、T-3、T-7	T-8	T-4	T-1	A-2	T-6
加解密功能	A-1	A-1	A-1	A-1	A-1	A-1

資料來源：本指引整理

本文件之智慧財產權屬行政院資通安全辦公室所有。

4.1.4. 威脅分級與排序 DREAD 評鑑標準

本案例進行 STRIDE 分析後得到了系統可能遭遇的威脅列表，在理想的安全過程當中，所有的威脅都應設計對應防護措施以獲得系統安全的保障，但現實專案當中往往受限於時間與成本各種考量，防範威脅與開發其對應的安全功能必須有所分級與排序，以確保最大的風險能優先被防範。因此微軟「安全發展生命週期」SDL 提出 DREAD 評鑑標準公式，透過此公式來協助開發人員衡量判斷各風險的權重，進而在系統開發生命週期中妥善分配資源與開發時程，網頁部落格的威脅對應評分表，詳見表 29。

表29 網頁部落格威脅對應評分表

威脅項目	對應項目	發生可能性			影響		風險值
		可重製性	可刺探性	可發現性	可能傷害	影響人數	
T-1 系統錯誤訊息導致資訊洩漏	公開文章列表(文章列表功能對匿名使用者)	2	2	2	1	1	12
	私人文章列表(文章列表功能對已登入使用者)	2	2	1	1	1	10
	使用者資訊(使用者驗證功能對匿名使用者)	2	2	1	1	1	10
	使用者資訊(已登入使用者對修改使用者資訊功能)	2	2	1	1	1	10

本文件之智慧財產權屬行政院資通安全辦公室所有。

威脅項目	對應項目	發生可能性			影響		風險值
		可重製性	可刺探性	可發現性	可能傷害	影響人數	
	文章列表功能	2	2	2	1	1	12
	刪除文章功能	2	2	1	1	1	10
	新增文章功能	2	2	1	1	1	10
	新增留言功能	2	2	1	1	1	10
	使用者驗證功能	2	2	2	1	1	12
	修改使用者資訊功能	2	2	1	1	1	10
T-2 中間人攻擊導致身分被冒用或資料被串改	文章內容(已登入使用者對新增文章功能)	1	1	1	2	1	9
	刪除請求(已登入使用者對刪除文章功能)	1	1	1	1	1	6
	使用者資訊(已登入使用者對修改使用者資訊功能)	1	1	1	1	1	6
	留言內容(已登入使用者對新增留言功能)	1	1	1	1	1	6
	已登入使用者	1	1	1	1	1	6
	文章列表功能	1	1	1	1	1	6
	刪除文章功能	1	1	1	2	1	9

本文件之智慧財產權屬行政院資通安全辦公室所有。

威脅項目	對應項目	發生可能性			影響		風險值
		可重製性	可刺探性	可發現性	可能傷害	影響人數	
	新增文章功能	1	1	1	2	1	9
	新增留言功能	1	1	1	2	1	9
	修改使用者資訊功能	1	1	1	3	1	12
T-3 使用者識別遭偽造或未登入可進行需登入之操作	已登入使用者	1	1	1	2	1	9
	刪除文章功能	1	1	1	1	1	6
	新增文章功能	1	1	1	1	1	6
	新增留言功能	1	1	1	1	1	6
	使用者驗證功能	1	1	1	2	1	9
	修改使用者資訊功能	1	1	1	3	1	12
T-4 使用者否認自己的操作行為	已登入使用者	1	1	1	1	1	6
	文章列表功能	1	1	1	1	1	6
	刪除文章功能	1	1	1	1	1	6
	新增文章功能	1	1	1	1	1	6
	新增留言功能	1	1	1	1	1	6
	使用者驗證功能	1	1	1	2	2	12
	修改使用者資訊功能	1	1	1	2	2	12

本文件之智慧財產權屬行政院資通安全辦公室所有。

威脅項目	對應項目	發生可能性			影響		風險值
		可重製性	可刺探性	可發現性	可能傷害	影響人數	
T-5 惡意使用者進行 Stored XSS 攻擊	文章列表功能	2	2	1	2	3	30
T-6 使用者透過網址修改進行非其權限資料操作	文章列表功能	2	2	2	1	3	24
	刪除文章功能	2	2	2	1	3	24
	新增文章功能	2	2	2	1	3	24
	新增留言功能	2	2	2	1	3	24
	修改使用者資訊功能	2	2	2	3	3	36
T-7 使用者遭受 CSRF 攻擊	刪除文章功能	2	2	2	1	3	24
	新增文章功能	2	2	2	1	3	24
	新增留言功能	2	2	2	1	3	24
	修改使用者資訊功能	2	2	2	2	3	30
T-8 惡意使用者使用注入式攻擊	刪除文章功能	2	2	2	2	3	30
	新增文章功能	2	2	2	2	3	30
	新增留言功能	2	2	2	2	3	30
	使用者驗證功能	2	2	2	2	3	30

本文件之智慧財產權屬行政院資通安全辦公室所有。

威脅項目	對應項目	發生可能性			影響		風險值
		可重製性	可刺探性	可發現性	可能傷害	影響人數	
	修改使用者資訊功能	2	2	2	2	3	30
T-9 惡意使用者透過暴力法進行密碼破解	使用者驗證功能	1	2	2	3	2	30
T-10 使用者帳戶遭駭，洩漏使用者各資	使用者資訊(使用者驗證功能對匿名使用者)	1	1	2	3	1	16
T-11 傳輸過程遭竊聽	使用者資訊(已登入使用者對修改使用者資訊功能)	2	2	2	3	1	24
	帳號密碼(匿名使用者對使用者驗證功能)	2	2	2	3	1	24
T-12 送出大量請求，導致服務中斷	刪除文章功能	2	2	2	2	2	24
	新增文章功能	2	2	2	2	2	24
	新增留言功能	2	2	2	2	2	24

資料來源：本指引整理

完成 DREAD 評鑑標準排序後，開發人員可以透過排序風險值來進行威脅的權重排序，藉此達到開發資源配置的最佳化。透過此表可發現相同的威

本文件之智慧財產權屬行政院資通安全辦公室所有。

脅在不同的對應項目中會有不同的風險值，但若這個風險的控制措施是屬於架構面的改動，則應以最大風險值看待。以編號 T-6 項目「使用者透過網址修改進行非其權限資料操作」為例，此威脅除了對應到「修改使用者資訊功能」外風險值皆為 24，但於「修改使用者資訊功能」具有敏感個資外洩之考量導致風險值提升為 30，而該風險對應的控制措施「導入使用者權限控機制」為架構面的安全需求，影響範圍涉及該風險所對應的所有項目，於是在安全需求此風險所對應的控制措施也應以風險值 30 看待。

4.1.5. 建立安全需求規格

此階段的目的在於將威脅建模後產生的安全需求規格回饋至原本的需求規格中，以滿足安全軟體開發的目的。網頁部落格經分析後共歸納出 12 種威脅，對應 DREAD 評鑑標準表格，可看出這 12 種威脅共在整個系統資料流程中產生 55 個資訊安全風險，但這不代表 12 個威脅對應的 11 種控制措施必須多次重複開發，許多功能可以透過架構設計或元件的共用獲得解決。以編號 T-6 項目「使用者透過網址修改進行非其權限資料操作」為例，在 Java EE 的架構中是可以透過 Filter 機制[24]進行集中式的控管以降低開發的成本。因此安全性需求規格往往會與系統設計規格及使用的開發技術息息相關，本指引透過網頁部落格威脅與控制措施對應表整理出的安全需求規格，並依據 DREAD 評鑑標準分析結果排序，詳見表 30。

表30 網頁部落格安全功能表

編號	高階需求	功能需求	風險值
B-S-01	導入使用者權限控機制	透過 Java EE Filter 功能攔截所有使用者請求進行使用者權限管制	36

本文件之智慧財產權屬行政院資通安全辦公室所有。

編號	高階需求	功能需求	風險值
B-S-02	驗證所有使用者輸入	透過 Java EE Filter 功能搭配 RequestWrapper 進行所有使用者輸入過濾	30
B-S-03	導入 CSRF Token 機制	所有表單處理前皆需驗證頁面產生的一次性的 CSRF Token 是否有效	30
B-S-04	所有輸出內容應經編碼後顯示	使用 JSTL 進行輸出內容呈現	30
B-S-05	帳戶於 30 分鐘內登入錯誤達 3 次後鎖定	建立使用者帳號與連線 IP 紀錄黑名單，若達錯誤門檻則加入鎖定 30 分鐘	30
B-S-06	於刪除文章功能導入 CAPTCHA 機制防止自動化攻擊	使用 Google reCAPTCHA[25] 於刪除文章頁面	24
B-S-07	於新增文章功能導入 CAPTCHA 機制防止自動化攻擊	使用 Google reCAPTCHA 於新增文章頁面	24
B-S-08	於新增留言功能導入 CAPTCHA 機制防止自動化攻擊	使用 Google reCAPTCHA 於新增留言頁面	24
B-S-09	使用 SSL 加密協定進行傳輸	於網頁伺服器中設定 SSL 服務，並設定系統中所有頁面皆透過 SSL 傳輸	24
B-S-10	所有使用者個資皆透過遮罩處理	於使用者個人資料頁面對姓名、電話號碼、信箱與住址等個人資料輸出進行遮罩處理	16

本文件之智慧財產權屬行政院資通安全辦公室所有。

編號	高階需求	功能需求	風險值
B-S-11	透過 Java EE Exception Handling 機制，確保系統錯誤訊息不洩漏給使用者	設計錯誤頁面，並於 web.xml 中設定將所有例外錯誤頁面導致錯誤頁面	12
B-S-12	使用 JAVA EE Session Management 功能進行使用者識別	透過並透過 JAVA EE Filter 檢查所有須登入功能存取的 Session 有效性，並設定 Session 有效時間為 30 分鐘	12
B-S-13	所有操作應經過 Log 機制進行紀錄保存	導入 log4j，並實作於所有使用者操作功能	12

資料來源：本指引整理

得到此安全功能後，即可將其回饋至系統需求，如將安全性需求加入原本的需求追溯矩陣，比如在系統設計規格書(Software Design Document)詳細描述安全需求規格之設計與實作方法，並於系統測試計畫(Software Test Plan)中設計相關的測試案例，透過需求追溯矩陣清楚的對照追蹤這些安全性需求是否被妥善設計與測試，詳見表 31。

本文件之智慧財產權屬行政院資通安全辦公室所有。

表31 網頁部落格安全需求追溯矩陣範例

專案名稱		網頁部落格		專案經理	○○○		專案期程	YY/MM/DD	
專案說明		網頁部落格							
編號	功能 ID	高階需求	功能需求	狀態	設計/技術規格	實作 模組/元件	測試案例 編號	測試時間	測試 結果
1	B-S-01	導入使用者權限控機制	透過 Java EE Filter 功能攔截所有使用者請求進行使用者權限管制	開啟	網頁部落格系統設計規格書 P.31	實作於使用者認證權限控管模組	T-S-01	N/A	N/A
2	B-S-02	驗證所有使用者輸入	透過 Java EE Filter 功能搭配 RequestWrapper 進行所有使用者輸入過濾	開啟	網頁部落格系統設計規格書 P.31	實作於安全驗證模組	T-S-02	N/A	N/A
3	B-S-03	導入 CSRF Token 機制	所有表單處理前皆需驗證頁面產生的	開啟	網頁部落格系統設計規格書	實作於安全驗證模組	T-S-03	N/A	N/A

本文件之智慧財產權屬行政院資通安全辦公室所有。

專案名稱		網頁部落格		專案經理	○○○		專案期程	YY/MM/DD	
專案說明		網頁部落格							
編號	功能 ID	高階需求	功能需求	狀態	設計/技術規格	實作 模組/元件	測試案例 編號	測試時間	測試 結果
			一次性的 CSRF Token 是否有效		P.33				
4	B-S-04	所有輸出內容應經編碼後顯示	使用 JSTL 進行輸出內容呈現	開啟	網頁部落格系統設計規格書 P.34	實作於頁面顯示	T-S-04	N/A	N/A
5	B-S-05	帳戶於 30 分鐘內登入錯誤達三次後鎖定	建立使用者帳號與連線 IP 紀錄黑名單，若達錯誤門檻則加入鎖定 30 分鐘	開啟	網頁部落格系統設計規格書 P.35	實作於使用者認證權限控管模組	T-S-05	N/A	N/A
6	B-S-06	於刪除文章功能導入 CAPTCHA	使用 Google reCAPTCHA 於刪除文章頁面	開啟	網頁部落格系統設計規格書 P.36	實作於安全驗證模組	T-S-06	N/A	N/A

本文件之智慧財產權屬行政院資通安全辦公室所有。

專案名稱		網頁部落格		專案經理	○○○		專案期程	YY/MM/DD	
專案說明		網頁部落格							
編號	功能 ID	高階需求	功能需求	狀態	設計/技術規格	實作 模組/元件	測試案例 編號	測試時間	測試 結果
		機制防止自動化攻擊							
7	B-S-07	於新增文章功能導入 CAPTCHA 機制防止自動化攻擊	使用 Google reCAPTCHA 於新增文章頁面	開啟	網頁部落格系統設計規格書 P.36	實作於安全驗證模組	T-S-07	N/A	N/A
8	B-S-08	於新增留言功能導入 CAPTCHA 機制防止自動化攻擊	使用 Google reCAPTCHA 於新增留言頁面	開啟	網頁部落格系統設計規格書 P.36	實作於安全驗證模組	T-S-08	N/A	N/A
9	B-S-09	使用 SSL 加	於網頁伺服器中設	開啟	網頁部落格系	實作於伺服	T-S-09	N/A	N/A

本文件之智慧財產權屬行政院資通安全辦公室所有。

專案名稱		網頁部落格		專案經理	○○○		專案期程	YY/MM/DD	
專案說明		網頁部落格							
編號	功能 ID	高階需求	功能需求	狀態	設計/技術規格	實作 模組/元件	測試案例 編號	測試時間	測試 結果
		密協定進行傳輸	定 SSL 服務，並設定系統中所有頁面皆透過 SSL 傳輸		統設計規格書 P.37	器與專案設定			
10	B-S-10	所有使用者個資皆透過遮罩處理	於使用者個人資料頁面對姓名、電話碼、信箱與住址等個人資料輸出進行遮罩處理	開啟	網頁部落格系統設計規格書 P.38	實作於個人資料管理模組	T-S-10	N/A	N/A
11	B-S-11	透過 Java EE Exception Handling 機制，確保系統錯誤訊息不洩漏給使	設計錯誤頁面，並於 web.xml 中設定將所有例外錯誤頁面導致錯誤頁面	開啟	網頁部落格系統設計規格書 P.37	實作於專案設定	T-S-11	N/A	N/A

本文件之智慧財產權屬行政院資通安全辦公室所有。

專案名稱		網頁部落格		專案經理	○○○		專案期程	YY/MM/DD	
專案說明		網頁部落格							
編號	功能 ID	高階需求	功能需求	狀態	設計/技術規格	實作 模組/元件	測試案例 編號	測試時間	測試 結果
		用者。							
12	B-S-12	使用 JAVA EE Session Management 功能進行使用者識別。	透過並透過 JAVA EE Filter 檢查所有須登入功能存取的 Session 有效性，並設定 Session 有效時間為 30 分鐘	開啟	網頁部落格系統設計規格書 P.32	實作於使用者認證權限控管模組	T-S-12	N/A	N/A
13	B-S-13	所有操作應經過 Log 機制進行紀錄保存。	導入 log4j，並實作於所有使用者操作功能	開啟	網頁部落格系統設計規格書 P.32	實作於行為紀錄模組	T-S-13	N/A	N/A

資料來源：本指引整理

本文件之智慧財產權屬行政院資通安全辦公室所有。

4.2.案例二 Mobile Threat Analysis

前一案例中所介紹的為傳統對外網站服務為例子，針對新型行動裝置應用程式開發議題上，由於行動裝置端所面對的資安威脅議題與傳統大型網站專案對比，程式開發期程、投入人力與規模相對較小，所面對的資安議題除容易被忽略也較不為開發團隊熟悉，故本案例以行動裝置開發所面臨的威脅[23]為例給予機關參考之依據。

4.2.1. 行動裝置應用程式資產

攻擊樹之發展可以依循下列流程發展：

- 識別出對應用程式之重要資產。
- 攻擊可能發生的地方(攻擊面)。
- 可能面臨的安全威脅。
- 是否有適當的安全控制措施。

首先考量行動裝置中所欲保護的資產，下列為可能之資產：

- 應用程式中的資料。
- 個人資料、交易訊息、應用程式機密資訊。

4.2.2. 行動裝置應用程式面臨之攻擊面

行動裝置可能面臨的攻擊面包含：

- 本地端儲存媒介(Log, Cache 與 SD 卡)。
- 與後端 Server 之連線。
- 與第三方服務之連線(Cloud Service)。

本文件之智慧財產權屬行政院資通安全辦公室所有。

●惡意的使用者

●Web 瀏覽與內容處理。

●暴露的 API(Application Platform Interface)與 RPC(Remote Procedure Call)。

●使用第三方的元件。

4.2.3. 行動裝置應用程式面臨的威脅分析

針對行動裝置應用程式可能面臨的威脅，可從資產會面臨威脅觀點發展。

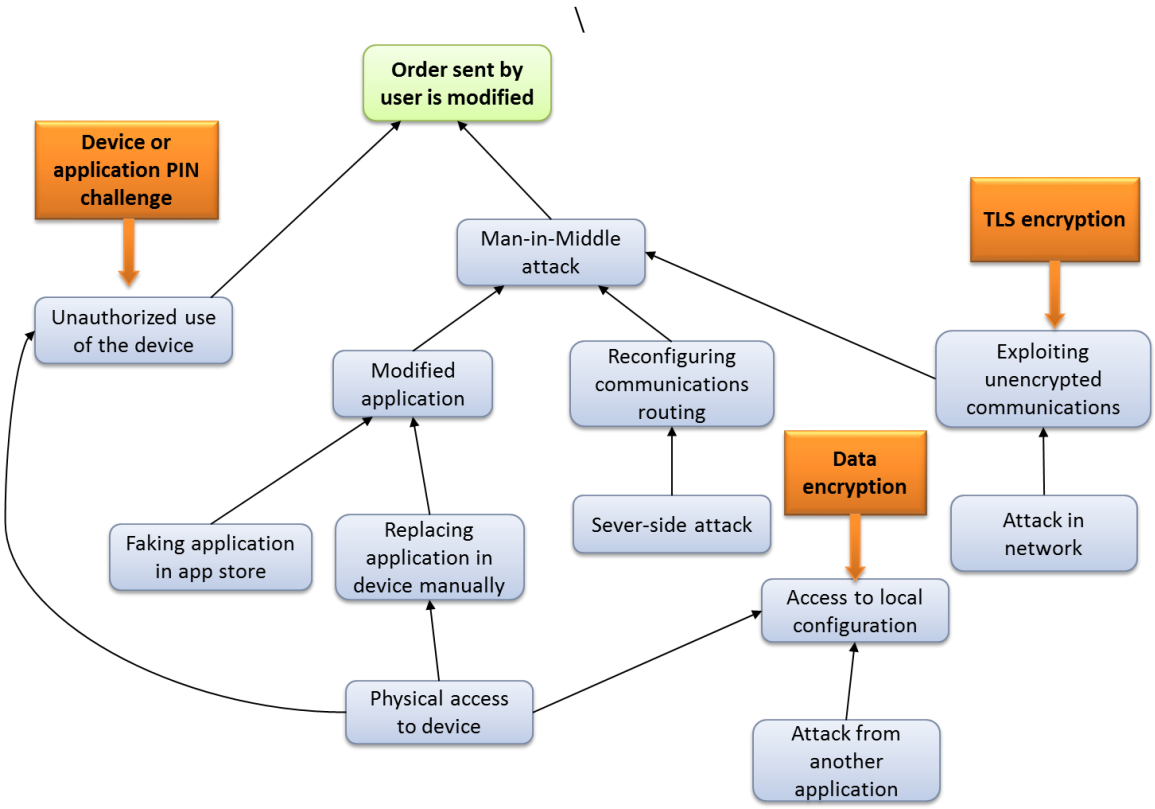
●應用程式中資訊資產的完整性、可用性、機密性與不可否認性。

●以 STRIDE 來思考資料流的處理過程。

●從攻擊面為出發點延伸。

因此所分析出之行動裝置應用程式 Attack Tree，詳見圖 33。

本文件之智慧財產權屬行政院資通安全辦公室所有。



資料來源：[23]

圖33 行動裝置應用程式 Attack Tree

所發展出來的攻擊樹包含 OWASP Mobile Top 10 RISKS 的威脅項目，詳見表 32。

表32 OWASP Mobile Top 10 RISKS 2014

風險編號	風險描述
M1	Weak Server Side Controls
M2	Insecure Data Storage
M3	Insufficient Transport Layer Protection

本文件之智慧財產權屬行政院資通安全辦公室所有。

風險編號	風險描述
M4	Unintended Data Leakage
M5	Poor Authorization and Authentication
M6	Broken Cryptography
M7	Client Side Injection
M8	Security Decisions Via Untrusted Inputs
M9	Improper Session Handling
M10	Lack of Binary Protections

資料來源：本指引整理

此外亦可參考 ENISA: Top Ten Smartphone Risks，包含下列可能之威脅：

●Abuse of client side paid resources。

● Failure to properly handle inbound SMS messages。

●Failure to properly handle outbound SMS messages。

●Malicious / fake applications from app store。

●Ability of one application to view data or communicate with other applications。

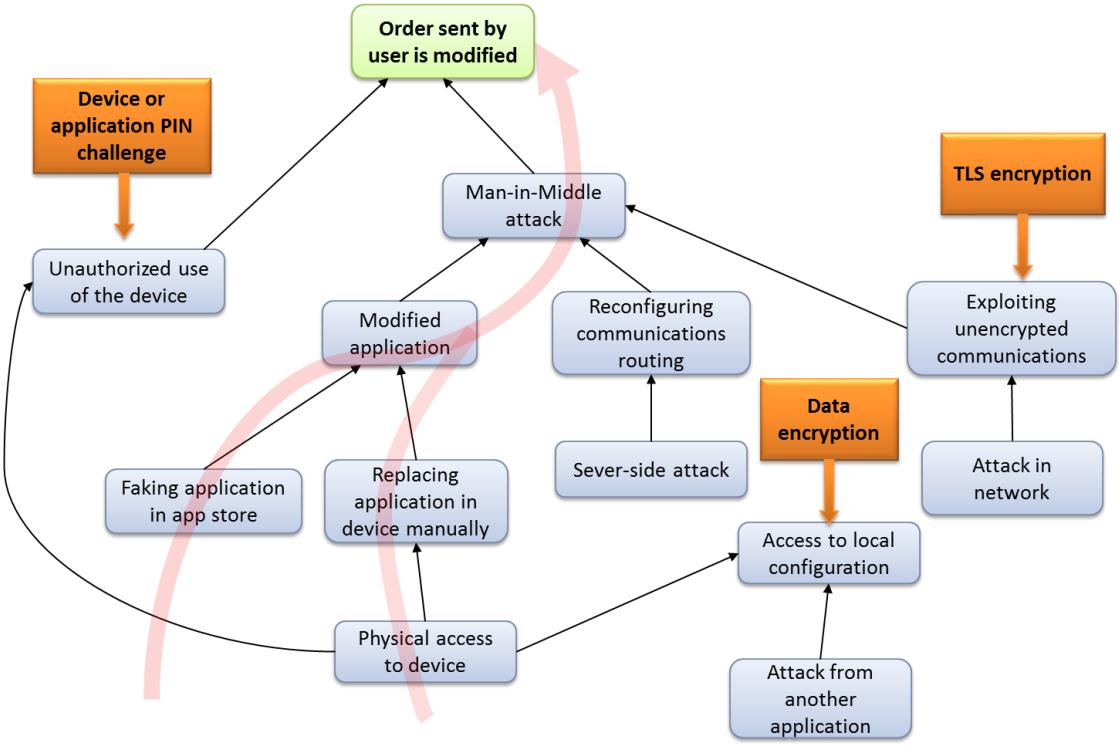
●Switching networks during a transaction。

●Failure to protect sensitive data at rest。

本文件之智慧財產權屬行政院資通安全辦公室所有。

●Failure to disable insecure platform features in application (caching of keystrokes, screen data)。

由攻擊樹所發展出之威脅列表後，因非每一個風險皆須處理，故針對行動裝置應用程式所面臨之風險仍可套用 DREAD 評鑑標準來對威脅進行權重與排序，詳見圖 34。



資料來源：[23]

圖34 行動裝置應用程式 Attack Tree Mitigation

由此樹葉點(Leaf node)往根節點之路徑可視為一威脅攻擊之情境，如此案例中所識別出的資產為應用程式中所送出的訂單，使用者可透過實體取得行動裝置後(攻擊面)，人工替換裝置上之應用程式造成應用程式被修改，產生中間人攻擊之影響(攻擊發生造成的影響)，造成使用者透過應用程式送出的

本文件之智慧財產權屬行政院資通安全辦公室所有。

訂單遭修改(可能面臨的安全威脅)，而圖中的黃色方塊中所述之啟用 PIN Code 驗證機制即為因應此安全威脅所套用的控制措施。

透過套用 Attack Tree 發展出行動裝置應用程式所面臨之威脅後，如前述章節與案例一所示，組織可針對威脅制定與選用適用的控制措施消弭行動裝置應用程式之安全威脅，強化行動裝置應用程式之安全設計。Attack Tree 發展出行動裝置應用程式所面臨之威脅後，如前述章節與案例一所示，組織可針對威脅制定與選用適用的控制措施消弭行動裝置應用程式之安全威脅。

本文件之智慧財產權屬行政院資通安全辦公室所有。

5. 結論

本指引主要探討安全軟體設計標準與方法論，包含如微軟 SDL, NIST SP 800-64, OWASP SAMM 等安全軟體發展規範中，針對安全軟體設計進行歸納並彙整各方法論共通之設計指引，作為安全軟體設計重要流程步驟。協助相關人員於軟體設計時，因應軟體風險管理議題，進行資產識別、風險評鑑、風險分析與風險處理過程，作為後續開發階段遵循與驗證之依據。

此外提出兩項案例，分別為常見之 Web 應用程式，以及行動裝置應用程式設計，進行實務分析。在 Web 應用程式中，協助單位了解針對設計 Web 專案中，如何以透過建議資料流程圖、套用 STRIDE 分析模型進行軟體威脅建模，並針對識別出之軟體安全威脅後，套用 DEARD 至傳統風險分級方法後，將威脅進行權重與排序，以協助組織針對風險值判斷是否針對風險進行接受或進行後續之選定控制措施並實行之階段，有效掌握並控管軟體專案之風險；另針對新興之行動裝置應用程式設計上，以案例提供應用程式資產之識別，並透過整合 OWASP Mobile Top 10 與 ENISA: Top Ten Smartphone Risks，發展資安威脅之攻擊樹，提供單位於行動裝置應用程式類型所面臨之資安風險，以進行後續之風險管控基礎。

本指引詳述安全軟體設計方法論與流程步驟，提供單位於軟體專案開發中藉由需求階段與設計階段之安全需求發展，安全風險識別與控制措施套用作為後續之安全功能驗證基礎之整合,期能落實安全軟體生命週期之實踐，有效從源頭強化整體資訊系統之安全性，強化政府整體安全軟體發展能量。

本文件之智慧財產權屬行政院資通安全辦公室所有。

6. 參考文獻

[1] http://www.softwaremag.com/DSN/wwwswmagcom/Content/ClientAssets/ISC_WPaper_03-20-14.pdf

[2] Simplified Implementation of the SDL, Microsoft

[3] Basics of Secure Design Development Test, Microsoft

[4] "Security Considerations in the System Development Life Cycle", The National Institute of Standards and Technology (NIST), http://csrc.nist.gov/publications/nistpubs/800-64-Rev2/SP800-64-Revision2.pdf, NIST 800-64

[5] “Standards for Security Categorization of Federal Information and Information Systems”, The National Institute of Standards and Technology (NIST), http://csrc.nist.gov/publications/fips/fips199/FIPS-PUB-199-final.pdf, FIPS PUB 199

[6] National Vulnerability Database, http://nvd.nist.gov/

[7] “Guide for Developing Security Plans for Federal Information Systems”, The National Institute of Standards and Technology (NIST), http://csrc.nist.gov/publications/nistpubs/800-18-Rev1/sp800-18-Rev1-final.pdf

[8] “Software Assurance Maturity Model – A guide to building security into software development version 1.0”, OWASP

[9] NIST SP 800-30, Risk Management Guide for Information Technology Systems

本文件之智慧財產權屬行政院資通安全辦公室所有。

[10]Joseph Yoder and Jeffrey Barcalow. Architectural Patterns for Enabling Application Security, 1997.

[11]Ronald Wassermann and Betty H.C. Cheng. Security Patterns

[12]Attack Surface Analysis Cheat Sheet,https://www.owasp.org/index.php/Attack_Surface_Analysis_Cheat_Sheet

[13]OWASP_Zed_Attack_Proxy_Project,https://www.owasp.org/index.php/OWASP_Zed_Attack_Proxy_Project

[14]Arachni,http://www.arachni-scanner.com/

[15]Skipfish,https://code.google.com/p/skipfish/

[16]MS-Style Threat Modeling , http://msdn.microsoft.com/en-us/library/aa302419.aspx

[17]Improving Web Application Security Threats and Countermeasures,Microsoft

[18]Schneier, Bruce. "Attack Trees: Modeling Security Threats." Dr. Dobbs' Journal: Dec 1999

[19]http://www.microsoft.com/en-us/download/details.aspx?id=42518

[20]Cigital Architecture Risk Analysis , http://www.cigital.com/presentations/ARA10.pdf

[21]99 年技術服務中心 Web 應用程式安全檢核表

[22]https://www.owasp.org/index.php/OWASP_Secure_Application_Design_Project

本文件之智慧財產權屬行政院資通安全辦公室所有。

[23]https://www.owasp.org/images/c/c9/Mobile-threat-analysis-short-presentation_owasp.pdf

[24]http://docs.oracle.com/javaee/6/tutorial/doc/bnagb.html

[25]http://www.google.com/recaptcha/intro/index.html

本文件之智慧財產權屬行政院資通安全辦公室所有。